

Daily Vulnerability Report - 2026-09-29

Window (UTC): 2026-09-28T06:15 to 2026-09-29T06:15 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-29 06:16:26 UTC

Total	New	Updated	KEV added	KEV	Critical	High	Medium	Unscored	Watchlist
465	409	56	0	2	47	126	161	101	273

New today - published in this report window

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101072	New	10.0	CRIT				A vulnerability was identified in Netcore NR289-GE 1.4.5102. This issue affects the function system of the file /ap_ip.cgi of the component CGI Handler. Such manipulation of the argument ip leads to os command injection. The attack can be launched remotely. The exploit is publicly available and might be used. The vendor was contacted early about this disclosure but did not r...
CVE-2026-101076	New	10.0	CRIT				A vulnerability was detected in Netcore NR289-GE 1.4.5102. This affects the function system of the file /set_ntp_server_ip.cgi of the component CGI Handler. The manipulation of the argument ntp_ip results in os command injection. The attack can be executed remotely. The exploit is now public and may be used. The vendor was contacted early about this disclosure but did not re...
CVE-2026-101077	New	10.0	CRIT				A flaw has been found in Netcore NR289-GE 1.4.5102. This impacts the function process_request of the component boa_temp Handler. This manipulation causes missing authentication. The attack is possible to be carried out remotely. The exploit has been published and may be used. The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-102240	New	10.0	CRIT				A vulnerability was found in Netcore NAP930 0.1.241010.141410. This affects the function eval of the file /www/cgi-bin/network_tools of the component Network Tools CGI. The manipulation of the argument sid results in os command injection. The attack may be performed from remote. The exploit has been made public and could be used. The vendor was contacted early about this dis...
CVE-2026-101037	New	9.9	CRIT				A vulnerability was found in FAST FAC1200R 5.0_20201119_1.0.2. Affected is the function parse_advertisement_frame of the component devdiscover Service. The manipulation results in stack-based buffer overflow. The attack may be launched remotely. The exploit has been made public and could be used. The vendor was contacted early about this disclosure but did not respond in any...
CVE-2026-101038	New	9.9	CRIT				A vulnerability was determined in FAST FAC1200R 5.0_20201119_1.0.2. Affected by this vulnerability is the function MmtAtePrase of the component MmtAtePrase Parser. This manipulation causes stack-based buffer overflow. Remote exploitation of the attack is possible. The exploit has been publicly disclosed and may be utilized. The vendor was contacted early about this disclosur...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82377	New	9.9	CRIT				Missing Authorization in Apache Roller 6.1.5 allows an authenticated user to read, modify, or delete weblog content belonging to other weblogs through the legacy XML-RPC Blogger and MetaWeblog APIs, because the handlers authenticate the caller but do not verify the caller's permission on the weblog or entry actually affected. Only installations that enable the non-default gl...
CVE-2026-85526	New	9.9	CRIT				Path traversal in the Btrfs storage driver (unpackVolume) in Canonical LXD on Linux allows an authenticated user with instance creation privileges to delete or replace arbitrary files and directories on the host filesystem as root via a crafted subvolumes[].path entry in backup/optimized_header.yaml during a btrfs optimized backup import.
CVE-2026-87799	New	9.9	CRIT				Improper link resolution in the migration receive path in Canonical LXD versions 4.0 and later (fixed in 4.0.14, 5.0.10, 5.21.8 and 6.10) on Linux allows an authenticated client that can create instances or custom storage volumes in a project, or a malicious migration source server, to write attacker-controlled files to arbitrary paths on the target host as root, leading to ...
CVE-2026-82384	New	9.8	CRIT				Deserialization of Untrusted Data in Apache Roller 6.1.5 allows an unauthenticated remote attacker to cause deserialization of attacker-controlled bytes, because the XML-RPC endpoint accepts vendor extension types that are deserialized during request parsing, before authentication. The servlet is mapped unconditionally, so parsing occurs even when the global XML-RPC feature ...
CVE-2026-90924	New	9.8	CRIT				Use of default credentials vulnerability in Innotim Software, Telecommunications and Consultancy Trade Ltd. Co. Logsign SIEM allows Try Common or Default Usernames and Passwords. This issue affects Logsign SIEM: from 6.4.101 before 6.4.117.
CVE-2026-101354	New	9.6	CRIT				A security flaw has been discovered in FAST FAC1203R 20200116_2.0.4. The affected element is the function _tWlanTask of the component MmtAtePrase Parser. Performing a manipulation results in stack-based buffer overflow. The attacker must have access to the local network to execute the attack. The exploit has been released to the public and may be used for attacks. The vendor...
CVE-2026-12342	New	9.6	CRIT				This vulnerability impacts all versions of IdentityIQ and allows an unauthenticated user remote code execution on the IdentityIQ server due to improper input validation of submitted web service API content.
CVE-2026-85185	New	9.6	CRIT				Path traversal in the btrfs storage driver in Canonical LXD versions 4.0.2 and later (fixed in 4.0.14, 5.0.10, 5.21.8 and 6.10) on Linux allows an authenticated client with permission to create instances in a project to delete arbitrary files on the host as root. On hosts whose root filesystem is btrfs, the client can also place attacker-controlled content at arbitrary host ...
CVE-2026-88804	New	9.6	CRIT				An unauthenticated update of public UI settings could be used by remote attackers to execute a stored cross-site scripting attack in the Rancher UI, in SUSE Rancher 2.15 before 2.15.2, 2.14 before 2.14.6, 2.13 before 2.13.10, 2.12 before 2.12.14 and 2.11 before 2.11.18.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-19759	New	9.4	CRIT				An Incorrect Authorization vulnerability in the task configuration in Google Cloud Application Integration versions prior to 2026-06-17 on Google Cloud Platform allows an authenticated Google Cloud user to execute arbitrary internal RPCs from inside Google's production network under a privileged identity using an internal-only task type. This vulnerability was patched on 1...
CVE-2026-81867	New	9.4	CRIT				A Deserialization of Untrusted Data vulnerability in the JavaScript Task in Google Cloud Application Integration versions prior to 2026-06-28 on Google Cloud Platform allows an authenticated user with standard permissions to run arbitrary code on the shared production servers using a specially crafted script bypassing param guards. This vulnerability was patched on 28 June...
CVE-2026-100752	New	9.3	CRIT				Joomla Extension - ordasoft.com - Unauthenticated SQL Injection in Real Estate Manager (Free) < 6.7.9 - site/realestatemanager.php builds the ORDER BY clause of three separate frontend property-listing queries (category browsing, search results, and the full property listing) from a request-controlled order_field parameter, concatenated directly into an unquoted SQL clause w...
CVE-2026-101039	New	9.3	CRIT				A vulnerability was identified in FAST FAC1900R 20190827_2.0.2. Affected by this issue is the function copy_msg_element of the component devdiscover Service. Such manipulation leads to stack-based buffer overflow. The attack can be executed remotely. The exploit is publicly available and might be used. The vendor was contacted early about this disclosure but did not respond ...
CVE-2026-101075	New	9.3	CRIT				A security vulnerability has been detected in Netcore NR289-GE 1.4.5102. The impacted element is the function system of the file /location_time.cgi of the component Location Time Handler. The manipulation of the argument mac leads to os command injection. Remote exploitation of the attack is possible. The exploit has been disclosed publicly and may be used. The vendor was co...
CVE-2026-101108	New	9.3	CRIT				Joomla Extension - ordasoft.com - Unauthenticated SQL Injection in Vehicle Manager (Free) < 6.5.8 - site/vehiclemanager.php reads the order_field and order_direction sort parameters at three separate anonymous-reachable frontend entry points (category listing, search, and the all-vehicles listing) through a sanitizing function that applies real escaping, but the value is the...
CVE-2026-101110	New	9.3	CRIT				Joomla Extension - ordasoft.com - Unauthenticated SQL Injection in Book Library (Free) < 6.4.6 - site/booklibrary.php's books() function reads the field and direction request parameters and passes each through a function called protectInjectionWithoutQuote(), whose only real protection is a keyword blacklist that, on detecting the literal substring select, wraps the value in...
CVE-2026-101891	New	9.3	CRIT				An improper access control vulnerability in an internal API service on WatchGuard Access Points allows an unauthenticated attacker with network access to the AP to obtain a valid API session.
CVE-2026-73640	New	9.3	CRIT				Dayforce Payroll is vulnerable to Time Based-Blind SQL Injection in password recovery functionality. The unauthenticated attacker can prepare GET request with one of the parameters filled in with an arbitrary SQL query. The parameter is interpreted as part of SQL predicate resulting in Time-Based Blind SQL Injection. Because vendor contact attempts were unsuccessful, the vul...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86102	New	9.3	CRIT				An OS command injection vulnerability in the WatchGuard AP internal API service allows an attacker with network access to the AP to execute arbitrary shell commands on the underlying operating system.
CVE-2026-102422	New	9.2	CRIT				shell-quote's <code>`quote()</code> function emits a <code>{ comment }</code> token as <code>`#`</code> followed by its text, which comments out the rest of the shell line, including the opening quote of any later string token. A line terminator (<code>\n</code> , <code>\r</code> , U+2028, U+2029) in that later string therefore ends the comment, and the rest of the string is parsed as shell input: <code>`quote(['echo', 'ok', { comment: 'x' }, ...</code>
CVE-2026-73642	New	9.2	CRIT				Dayforce Payroll is vulnerable to Path Traversal in file download functionality. An unauthenticated attacker can send GET request with file path parameter set to any path including an absolute local file path. Because vendor contact attempts were unsuccessful, the vulnerability has only been confirmed in version R2026.2.0 but may also affect other versions.
CVE-2026-101081	New	9.1	CRIT				A security flaw has been discovered in D-Link DI-8400 16.07. This vulnerability affects the function <code>menu_nat_more_asp</code> of the file <code>menu_nat_more.asp</code> of the component Web Administration Service. The manipulation of the argument <code>opt</code> results in stack-based buffer overflow. The attack can be launched remotely. The exploit has been released to the public and may be used for attacks.
CVE-2026-101187	New	9.1	CRIT				A weakness has been identified in Ziroom ZHOME A0101 1.0.1.0. This vulnerability affects the function <code>pop_usb_device</code> of the file <code>usr/lib/luas/luci/controller/api/zrUsb.lua</code> of the component USB Device Management API. This manipulation of the argument <code>path</code> causes command injection. The attack is possible to be carried out remotely. The exploit has been made available to the pub...
CVE-2026-101260	New	9.1	CRIT				A vulnerability was detected in Ziroom ZHOME A0101 1.0.1.0. Affected by this issue is some unknown functionality of the file <code>/api/ZRnetwork/firstLogin</code> . Performing a manipulation of the argument <code>firstLogin</code> results in command injection. The attack is possible to be carried out remotely. The exploit is now public and may be used. The vendor was contacted early about this disclo...
CVE-2026-101261	New	9.1	CRIT				A flaw has been found in Ziroom ZHOME A0101 1.0.1.0. This affects an unknown part of the file <code>/api/ZRnetwork/firstSetup_wifi</code> . Executing a manipulation of the argument <code>login_pwd</code> can lead to command injection. The attack may be performed from remote. The exploit has been published and may be used. The vendor was contacted early about this disclosure but did not respond in any ...
CVE-2026-101262	New	9.1	CRIT				A vulnerability has been found in Ziroom ZHOME A0101 1.0.1.0. This vulnerability affects unknown code of the file <code>/api/ZRQos/set_online_client</code> . The manipulation of the argument <code>ip</code> leads to command injection. It is possible to initiate the attack remotely. The exploit has been disclosed to the public and may be used. The vendor was contacted early about this disclosure but di...
CVE-2026-101263	New	9.1	CRIT				A vulnerability was found in Ziroom ZHOME A0101 1.0.1.0. This issue affects some unknown processing of the file <code>/api/ZRQos/set_online_client</code> . The manipulation of the argument <code>mac</code> results in command injection. It is possible to launch the attack remotely. The exploit has been made public and could be used. The vendor was contacted early about this disclosure but did not respo...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101264	New	9.1	CRIT				A vulnerability was determined in Ziroom ZHOME A0101 1.0.1.0. Impacted is an unknown function of the file /api/ZRnetwork/set_passwd. This manipulation of the argument password1 causes command injection. The attack can be initiated remotely. The exploit has been publicly disclosed and may be utilized. The vendor was contacted early about this disclosure but did not respond in...
CVE-2026-101894	New	9.1	CRIT				The decompress package for Node.js extracts archives. Prior to 10.2.2 and 11.1.4, the default decompress(input, output) API relies on lexical containment checks that do not account for the kernel following a planted symlink chain. An attacker can supply a crafted archive containing chained symlink entries so that a later entry resolves outside the output directory. This allo...
CVE-2026-102268	New	9.1	CRIT				PyJWT is a Python implementation of JSON Web Token standards. Prior to 2.14.0, is_pem_format in jwt/utls.py is affected because is_pem_format does not recognize every PEM representation accepted by the cryptography loader. This occurs when an application mixes HMAC and asymmetric algorithms and supplies a mutated public-key PEM as raw key bytes. As a result, HMACAlgorithm.p...
CVE-2026-102361	New	9.1	CRIT				mall4j through 4.0 contains a missing authentication vulnerability in the PUT /user/updatePwd endpoint that allows unauthenticated attackers to reset any storefront account password. Attackers can supply a target username in the request body to overwrite passwords without verification, enabling account takeover and access to orders and personal data.
CVE-2026-49994	New	9.1	CRIT				Bluehood monitors local bluetooth activity. Prior to version 0.7.1, when auth_enabled is set in Bluehood, only the HTML page handlers enforced session validation. The /api/* handlers (settings, devices, groups, per-device endpoints including /api/device/{mac}/notes) called no auth check at all. A network attacker reachable on the dashboard port could read Bluetooth tracking ...
CVE-2026-82378	New	9.0	CRIT				Incorrect Authorization in the OAuth 1.0a authorization endpoint of Apache Roller 6.1.5 allows an unauthenticated remote attacker who learns an outstanding request token for a configured site-wide consumer to bind that token to an arbitrary user account, including an administrator, by submitting an unsigned authorization request. The endpoint derives the authorizing identity...
CVE-2026-101074	New	8.9	HIGH				A weakness has been identified in Netcore NR289-GE 1.4.5102. The affected element is the function password-check of the file /bin/boa of the component Authentication. Executing a manipulation of the argument Username can lead to stack-based buffer overflow. The attack may be launched remotely. The exploit has been made available to the public and could be used for attacks. T...
CVE-2026-101860	New	8.8	HIGH				A vulnerability was found in RaspAP raspap-webgui up to 3.5.5. Affected by this issue is the function PluginInstaller::addSudoers of the file src/RaspAP/Plugins/PluginInstaller.php of the component sudo Configuration. Performing a manipulation results in improper privilege management. The attack may be initiated remotely. The exploit has been made public and could be used. T...
CVE-2026-12264	New	8.8	HIGH				Zohocorp ManageEngine DDI Central versions before 6201 are vulnerable to Arbitrary file write via HA Failover Config sync upload leading to remote code execution.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-12265	New	8.8	HIGH				Zohocorp ManageEngine DDI Central versions before 6201 are vulnerable to Insufficient access control in HA failover endpoint leading to destructive PostgreSQL database operations.
CVE-2026-12268	New	8.8	HIGH				ManageEngine DDI Central versions below 6201 are vulnerable to PowerShell command injection in Windows DNS SPF/TXT record push leading to remote code execution.
CVE-2026-12269	New	8.8	HIGH				Zohocorp ManageEngine DDI Central 6.2.0 build below 6201 had a Keepalived configuration injection vulnerability in the HA configuration workflow. This issue could allow an authenticated operator-level user to modify the Keepalived configuration and potentially execute commands as root on the DDI Central host.
CVE-2026-78424	New	8.8	HIGH				Improper parameter handling in NeuVector allows any authenticated user who holds the namespaced Runtime Policies (write) permission or anyone with access to NeuVector's internal gRPC certificate key pair the ability to inject OS commands in the privileged enforcer container, which can lead to the complete compromise of the worker node. This affects NeuVector 5.4 before 5.4.1...
CVE-2026-85134	New	8.8	HIGH				Unrestricted upload of file with dangerous type vulnerability in Bimser Solution Software Trade Inc. EBA Plus Document and Workflow Management System allows Upload a Web Shell to a Web Server. This issue affects eBA Plus Document and Workflow Management System: from 6.7.141 before 10.0.11.
CVE-2026-86595	New	8.8	HIGH				Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in Iron Mountain Archiving Services Inc. EnVision allows SQL Injection. This issue affects enVision: before 260655.
CVE-2026-86950	New	8.8	HIGH				An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 26.7.1 and iPadOS 26.7.1, macOS Sequoia 15.8.1, macOS Tahoe 26.7.1. Processing a maliciously crafted file may lead to arbitrary code execution. Apple is aware of a report that this issue may have been exploited in an extremely sophisticated attack against specific targeted in...
CVE-2026-87741	New	8.8	HIGH				The ConvertPlus plugin for WordPress is vulnerable to Deserialization of Untrusted Data in all versions up to, and including, 3.6.3 via the style parameter of the cp_display_preview_modal AJAX action. The vulnerability exists because the action's nonce guard is gated behind an isset() check and fails open when the cp_admin_page_nonce parameter is omitted entirely, no capabil...
CVE-2026-88808	New	8.8	HIGH				A vulnerability has been identified within Rancher Manager where the Fleet agent wrote resources to downstream clusters using its own cluster-admin credentials instead of the ServiceAccount pinned to the deployment. It affects multi-tenancy environments where different tenants share the same downstream clusters, for example different privileged or untrusted teams inside the ...
CVE-2026-90926	New	8.8	HIGH				Improper Control of Generation of Code ('Code Injection') vulnerability in Innотim Software, Telecommunications and Consultancy Trade Ltd. Co. Logsign SIEM allows Code Injection. This issue affects Logsign SIEM: from 6.4.101 before 6.4.117.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100371	New	8.7	HIGH				InvoicePlane is a self-hosted open source application for managing invoices, clients, and payments. In version 1.7.2, an authorization guard to Users::change_password(), was added to address a previous authorization flaw that allowed a secondary administrator (user_type=1, user_id != 1) to directly change the password of the primary administrator (user_id=1) through users/ch...
CVE-2026-48100	New	8.7	HIGH				Payy is an Ethereum L2 zk-rollup for privacy preserving and regulatory compliant transactions. Prior to version 1.3.0, agg_agg forwards the compacted message stream from its inner proofs into a public messages: [Field; 1000] array, but it never checks that the unused tail of the outer array is zero. A registered prover can build a valid agg_final proof for an approved rollup...
CVE-2026-54675	New	8.7	HIGH				FreePBX is an open source IP PBX. Prior to versions 16.0.10 and 17.0.5, a critical vulnerability exists in the sound language upload and conversion functionality that allows an authenticated attacker to perform arbitrary file writes, leading directly to remote code execution (RCE). Authentication with a known username is required. The vulnerability stems from insufficient pa...
CVE-2026-95104	New	8.7	HIGH				Stack-based buffer overflow vulnerability exists in BUFFALO Wi-Fi products. A non-authenticated crafted HTTP request may cause a denial-of-service (DoS) condition.
CVE-2026-96538	New	8.7	HIGH				WarehousePG (WHPG) 7.x before 7.6.0-WHPG is affected by a missing authorization vulnerability (CWE-862) in the built-in server-side file functions pg_file_write(text,text,bool), pg_file_rename(text,text,text), pg_file_unlink(text), and pg_logdir_Is(). These functions are executable by any authenticated database role with no GRANT required, because the REVOKE that contrib/adm...
CVE-2024-42002	New	8.6	HIGH				A code injection vulnerability has been discovered in the Robot Operating System 2 (ROS 2) 'ros2topic' command-line tool, affecting all ROS 2 distributions from Crystal Clemmys up to and including Lyrical Luth and Rolling Ridley. The vulnerability lies in the 'hz' verb, which reports the publishing rate of a topic and accepts a user-provided Python expression via the --filte...
CVE-2026-101002	New	8.6	HIGH				A security flaw has been discovered in Netcore NBR200V2 1.3.241127.071246. Affected is the function system of the file /usr/bin/network_tools of the component Tools Ping Handler. Performing a manipulation of the argument url results in os command injection. The attack can be initiated remotely. The exploit has been released to the public and may be used for attacks. The vend...
CVE-2026-54674	New	8.6	HIGH				FreePBX is an open source IP PBX. Prior to versions 16.0.39 and 17.0.7, users authenticated via User Control Panel (UCP) are able to execute arbitrary commands on the PBX as the webserver user (typically asterisk) using specially crafted HTTP strings. Authenticated access to UCP is required. Note that this is often more common for less-privileged users to have UCP access vs....
CVE-2026-54708	New	8.6	HIGH				FreePBX is an open source IP PBX. Prior to versions 16.0.72 and 17.0.7, a critical vulnerability exists in the FreePBX backup Module that allows authenticated attackers to execute arbitrary code on the server. Authentication with a known username that has sufficient access permissions and/or write access to backup files is required. This vulnerability is caused by improper p...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-54710	New	8.6	HIGH				FreePBX is an open source IP PBX. Prior to versions 16.0.40 and 17.0.7, a critical remote code execution (RCE) vulnerability exists in the superfecta module due to unsafe inclusion of arbitrary PHP files, allowing authenticated attackers to execute arbitrary PHP code on the server with the privileges of the web server user. Authentication with a known username is required. T...
CVE-2026-75600	New	8.6	HIGH				FreePBX is an open source IP PBX. Prior to version 17.0.9, authenticated users who are authorized to access the GraphQL api module interface of FreePBX are able to execute arbitrary shell commands. Authenticated access to the api module is required. The PBX API module's documentation generator accepts an authenticated host parameter and uses it to build a shell command. The ...
CVE-2026-86530	New	8.6	HIGH				BUFFALO Wi-Fi products handle some web form input improperly to assemble command line strings internally. An administrative user may send a crafted HTTP request and execute an arbitrary OS command.
CVE-2026-87969	New	8.6	HIGH				An OS command injection vulnerability in the WatchGuard AP diagnostic CLI allows an authenticated administrator to execute arbitrary operating system commands by supplying crafted input.
CVE-2026-100750	New	8.5	HIGH				Joomla Extension - regularlabs.com - LFI / SSRF in Modules Anywhere 1.5.0 - 9.0.5 for Joomla - Modules Anywhere Pro lets additional attributes on a module tag replace arbitrary parameters of the selected module. This feature is enabled by default in affected versions. The overrides are applied without checking who authored the content containing the tag. The security effect ...
CVE-2026-101007	New	8.5	HIGH				A vulnerability has been found in aaPanel BaoTa up to 11.8.0. This issue affects the function InputSql of the file class/database.py of the component Database Backup Handler. Such manipulation of the argument Password leads to os command injection. The attack can be executed remotely. The exploit has been disclosed to the public and may be used. The vendor was contacted earl...
CVE-2026-101008	New	8.5	HIGH				A vulnerability was found in aaPanel BaoTa up to 11.8.0. Impacted is the function merge_split_file of the file /www/server/panel/class/files.py of the component File Merge Handler. Performing a manipulation of the argument split_file_path results in command injection. The attack is possible to be carried out remotely. The exploit has been made public and could be used. The v...
CVE-2026-101009	New	8.4	HIGH				A vulnerability was determined in aaPanel BaoTa up to 11.8.0. The affected element is the function panelTask.bt_task._unzip of the file /www/server/panel/class/panelTask.py of the component Unzip Handler. Executing a manipulation of the argument Password can lead to os command injection. The attack may be performed from remote. The exploit has been publicly disclosed and may...
CVE-2026-55157	New	8.4	HIGH				Token Optimizer MCP measures token savings per AI coding agent, optimizes context, and shares a live local knowledge graph across 16 CLI clients. Prior to version 5.1.0, token-optimizer-mcp is vulnerable to OS command injection in the smart_user tool. Any MCP client that can call the smart_user tool can execute arbitrary shell commands through the username argument of the ge...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101073	New	8.3	HIGH				A security flaw has been discovered in Netcore NR289-GE 1.4.5102. Impacted is an unknown function of the file /bin/boa of the component CGI Dispatcher. Performing a manipulation results in improper authentication. The attack may be initiated remotely. The exploit has been released to the public and may be used for attacks. The vendor was contacted early about this disclosure...
CVE-2026-101188	New	8.3	HIGH				A security vulnerability has been detected in Netcore POWER13 2.0.240730.162638. This issue affects the function routerd.passwd_set of the file /ubus. Such manipulation leads to weak password recovery. The attack may be performed from remote. The exploit has been disclosed publicly and may be used. The vendor was contacted early about this disclosure but did not respond in a...
CVE-2026-101909	New	8.3	HIGH				Axios is a promise-based HTTP client for the browser and Node.js. From 0.28.0 until 0.34.0 and 1.15.1 until 1.20.0, ToFormData processes inherited serialization options and visitor properties supplied through prototype pollution. A separate same-process prototype-pollution flaw supplies inherited dots, indexes, metaTokens, maxDepth, visitor, or Blob values before object seri...
CVE-2026-81375	New	8.3	HIGH				A Confused Deputy vulnerability in the EmailTask component in Google Cloud Application Integration versions prior to 2026-06-30 on Google Cloud Platform allows an authenticated attacker to read and exfiltrate arbitrary Google-internal files via a crafted attachment file path. This vulnerability was patched on 30 June 2026, and no customer action is needed.
CVE-2026-101292	New	8.2	HIGH				Apache ActiveMQ Artemis before 2.34.0 contains an unsafe reflection vulnerability in FederationStreamConnectMessage.getFederationPolicy(). The method calls Class.forName(clazz).getConstructor().newInstance() where clazz is read directly from the CORE protocol wire buffer without type validation. An authenticated federation peer can send a FEDERATION_DOWNSTREAM_CONNECT packet...
CVE-2026-101901	New	8.2	HIGH				Axios is a promise-based HTTP client for the browser and Node.js. From 1.13.0 until 1.20.0, Http2Sessions does not install adequate error handling for a ClientHttp2Session during Axios HTTP/2 session initialization or reuse. A request uses httpVersion: 2 and the ClientHttp2Session emits an error during session initialization or reuse. The unhandled session error escapes norm...
CVE-2026-101903	New	8.2	HIGH				Axios is a promise-based HTTP client for the browser and Node.js. From 1.16.1 until 1.20.0, the RFC 2397 regular expression allows slash characters on both sides of the media-type separator. An application passes an attacker-controlled malformed data URL containing many slash characters and no comma. the JavaScript regular-expression engine explores many separator placements...
CVE-2026-101906	New	8.2	HIGH				Axios is a promise-based HTTP client for the browser and Node.js. From 1.15.0 until 1.20.0, Axios shouldBypassProxy applies a quadratic trailing-dot regular expression to redirect hostnames. HTTP_PROXY or HTTPS_PROXY is configured, NO_PROXY or no_proxy is non-empty, redirects are followed, and a crafted redirect Location contains many dots followed by a non-dot character. Ho...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-54160	New	8.2	HIGH				Network UPS Tools is a collection of programs which provide a common interface for monitoring and administering UPS, PDU and SCD hardware. Prior to commits 658b24e and 1aa31d1, the GitHub Actions script used to prepare NUT tarballs and update GitHub Checks statuses and PR comments about it was mis-structured in terms of mixing code running with higher privileges (single-use ...
CVE-2026-82383	New	8.2	HIGH				Missing Authentication for Critical Function in Apache Roller 6.1.5 allows an unauthenticated remote attacker to persistently change a site-global configuration value (the frontpage weblog selection) on any installed instance, because the setup action remains anonymously reachable after installation and persists configuration without an authorization check. No optional featu...
CVE-2026-91043	New	8.2	HIGH				Allocation of Resources Without Limits or Throttling vulnerability in elixir-mint mint allows a malicious HTTP/2 server to exhaust memory on the client host and cause a denial of service. Mint.HTTP2 enforces the client's max_header_list_size setting only on the compressed size of an inbound header block, while RFC 9113 section 6.5.2 defines the limit on the decoded header l...
CVE-2026-82323	New	8.1	HIGH				Authorization bypass through User-Controlled key vulnerability in Enocta Educational Technologies Inc. Enocta Platform allows Exploitation of Trusted Identifiers. This issue affects Enocta Platform: through 2026-09-28.
CVE-2026-82380	New	8.1	HIGH				Cross-Site Request Forgery (CSRF) in Apache Roller 6.1.5 allows a remote attacker to cause a logged-in user to perform state-changing actions under the victim's authority, because the CSRF validation filters accept a request that does not submit the required salt token, validating instead against a value the server itself generated for the request. No optional feature or non...
CVE-2026-88805	New	8.1	HIGH				Incorrect credential cleaning on logout could be used by remote attackers to keep access credentials even after the account was logged out. Affected is SUSE Rancher 2.15 before 2.15.2.
CVE-2026-93348	New	8.1	HIGH				Unsloth Zoo versions 2025.9.9 before 2026.8.14, as implemented in Unsloth 2025.9.9 through 2026.8.19, contains a code injection vulnerability in the model-loading compile path where the get_transformers_model_type() function in hf_utils.py collects model_type values from nested model configurations without enforcing a character allowlist, allowing newlines and arbitrary Pyth...
CVE-2026-93355	New	8.1	HIGH				LiteLLM contains a weak authentication vulnerability that allows an attacker holding a valid JWT from the configured identity provider to authenticate as any existing user by exploiting an email-based fallback lookup in the JWT authentication flow without verifying the email_verified claim. Attackers can present a token with an unverified email address matching a victim's ac...
CVE-2026-102004	New	7.8	HIGH				Wind River VxWorks 7 prior to 26.09, specific system call arguments can result in memory corruption within the memory management subsystem. Fixed in Version 26.09
CVE-2026-16513	New	7.8	HIGH				The userspace verifier z_vrfy_rtio_sqe_copy_in_get_handles() in subsys/rtio/rtio_syscalls.c (subsys/rtio/rtio_handlers.c before v4.3.0) validated the RTIO object handle and the sqes input array, but not the handle out-parameter. On the first loop iteration it executed *handle = sqe, storing the kernel address of the newly acquired submission-queue entry through a pointer tak...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-18413	New	7.8	HIGH				The ADC API requires each driver to reject a sampling sequence whose destination buffer is too small: the buffer_size field of struct adc_sequence in include/zephyr/drivers/adc.h documents that "the driver must ensure that samples are not written beyond the limit and it must return an error if the buffer turns out to be not large enough". The NXP MCUX LPADC driver did not ho...
CVE-2026-18414	New	7.8	HIGH				The ADC API requires each driver to reject a sampling sequence whose destination buffer is too small: the buffer_size field of struct adc_sequence in include/zephyr/drivers/adc.h documents that "the driver must ensure that samples are not written beyond the limit and it must return an error if the buffer turns out to be not large enough". The ADI MAX32 driver did not honour ...
CVE-2026-4556	New	7.8	HIGH				Exam4 is affected by a local privilege escalation vulnerability in the com.extegrity.LogTool privileged helper, which communicates with the application via XPC. The [ConsoleLogHelper copyConsoleIntoFileFromStartDate:] method executes a syslog command using attacker-controlled parameters without proper sanitization, enabling command injection. Successful exploitation allows a...
CVE-2026-45562	New	7.7	HIGH				FreePBX is an open source IP PBX. Prior to versions 16.0.4 and 17.0.6, the FreePBX Music on Hold (MoH) module contains a critical security flaw that allows authenticated attackers to execute arbitrary system commands with the privileges of the Asterisk service. Authentication with an existing FreePBX administrator account is required. The root cause lies in the fact that the...
CVE-2026-82348	New	7.7	HIGH				Authorization Bypass Through User-Controlled Key in Apache Roller 6.1.5 allows an authenticated user with authoring rights on one weblog to read, modify, or delete resources belonging to another weblog through unscoped identifier-based lookups. This affects multi-user installations where users are intended to be isolated between weblogs; no optional feature or non-default co...
CVE-2026-82376	New	7.7	HIGH				Improper Restriction of XML External Entity Reference in Apache Roller 6.1.5 allows a user with entry-editing rights on a weblog to cause the server to parse an attacker-influenced traceback response with an XML parser that does not disable external entity resolution, leading to disclosure of files readable by the Roller process. The Traceback control is hidden in the standa...
CVE-2026-82379	New	7.7	HIGH				Authentication Bypass by Capture-replay in Apache Roller 6.1.5 allows an attacker who captures a valid WSSE digest authentication header to replay it and gain the victim's AtomPub authority, because the authentication does not enforce nonce uniqueness or timestamp freshness. Only installations that enable the non-default AtomPub API with WSSE authentication and plaintext-com...
CVE-2026-82386	New	7.7	HIGH				Improper Restriction of XML External Entity Reference in Apache Roller 6.1.5 allows a weblog administrator to read files readable by the Roller process and reach internal network addresses by importing a crafted OPML document, because the bookmark import parser does not disable external entity resolution. No non-default configuration is required; the import is reached through...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82928	New	7.7	HIGH				mH-DEVELOPER smart home module contains a hardcoded SSH public key in /root/.ssh/authorized_keys, serving as a potential backdoor. The SSH daemon allows root login via key authentication and starts automatically. An attacker with the matching private key can gain a root shell on any affected device, resulting in full system compromise. The key cannot be removed without remou...
CVE-2026-97335	New	7.7	HIGH				Incorrect authorization in the custom storage volume creation endpoint in Canonical LXD versions 5.0.0 and later (fixed in 5.0.10, 5.21.8 and 6.10) on Linux allows an authenticated client with permission to create custom volumes in a project to copy, and so read, any custom storage volume from any other project on the server, including its snapshots and configuration. The cl...
CVE-2026-101905	New	7.6	HIGH				Axios is a promise-based HTTP client for the browser and Node.js. From 1.15.2 until 1.20.0, the Node HTTP adapter in lib/adapters/http.js supplies request options without an own createConnection value. A separate same-process prototype-pollution flaw places a function on Object.prototype.createConnection. Node resolves and invokes the inherited createConnection socket factor...
CVE-2026-55160	New	7.6	HIGH				Stringer is a self-hosted, anti-social RSS reader. Prior to commit 75cb095, an unrestricted Server-Side Request Forgery (SSRF) vulnerability allows any authenticated user to force the Stringer server to send arbitrary HTTP/HTTPS requests to internal networks, localhost services, and cloud metadata endpoints (e.g. AWS IMDS 169.254.169.254). When self-service signup is enabled...
CVE-2026-100751	New	7.5	HIGH				Joomla Extension - regularlabs.com - Privileged stored XSS via data-rlta-url attributes in Tabs & Accordions (Pro) 2.3.0 - 3.1.0 - Tabs & Accordions Pro accepts a url option for an item and writes it to a generated data-rlta-url attribute. The browser code passes that value to window.open() when the item is activated. Affected versions do not reject browser URL schemes which...
CVE-2026-101878	New	7.5	HIGH				Bitwarden Server 2025.6.0 before 2026.5.0 declares the @ExternalId parameter of the User_ReadBySsoUserOrganizationIdExternalId stored procedure as NVARCHAR(50) while the column it queries stores NVARCHAR(300), silently truncating the SSO login identifier on SQL Server deployments and allowing a user whose identity-provider identifier begins with another organization member's...
CVE-2026-102276	New	7.5	HIGH				The brace-expansion library generates arbitrary strings containing a common prefix and suffix. Prior to 1.1.19, 2.1.5, 3.0.7, and 5.0.10, crafted brace patterns can exhaust the native stack in parseCommaParts because parseCommaParts recursively processes the remainder once per brace group and uses push.apply to pass every element of a very large comma-part array as a functio...
CVE-2026-102278	New	7.5	HIGH				The brace-expansion library generates arbitrary strings containing a common prefix and suffix. Prior to 1.1.20, 2.1.6, 3.0.8, and 5.0.11, deeply nested brace groups cause expand_() to recurse once per nesting level at comma-member and single-set expansion sites, exhausting the native stack before output limits can apply and potentially terminating the Node.js process. expand...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102281	New	7.5	HIGH				Nest is a framework for building scalable Node.js server-side applications. Prior to 11.2.4 and 12.0.2, a single message with a deeply nested object in its pattern can terminate a NestJS microservice using the TCP or RabbitMQ transport. ServerTCP#handleMessage and ServerRMQ#handleMessage pass a client-controlled non-string pattern to JSON.stringify to derive the handler look...
CVE-2026-101916	New	7.4	HIGH				@grpc/grpc-js implements the core functionality of gRPC purely in JavaScript, without a C++ addon. Prior to 1.13.6 and 1.14.5, getAuthContext does not distinguish authorized from unauthorized peer certificates when server credentials set requireClientCertificate to false. When applications use the returned authentication context, they can treat an unauthorized certificate as...
CVE-2026-102243	New	7.4	HIGH				A vulnerability was identified in MODSetter SurfSense up to 2.0.3. This issue affects some unknown processing of the file /api/search-source/connectors/mcp/test of the component MCP Connector Integration. Such manipulation leads to command injection. It is possible to launch the attack remotely. The exploit is publicly available and might be used. The vendor was contacted ea...
CVE-2026-102266	New	7.4	HIGH				PyJWT is a Python implementation of JSON Web Token standards. From 2.13.0 until 2.14.0, HMACAlgorithm.from_jwk is affected because PyJWK verification path used the decoded key without applying prepare_key validation. This occurs when a trusted JWK Set contains an oct entry with an empty k value. As a result, an attacker signs an HMAC token with the same zero-length key accep...
CVE-2026-102267	New	7.4	HIGH				PyJWT is a Python implementation of JSON Web Token standards. Prior to 2.14.0, PyJWT PyJWKClient is affected because redirect destinations are not revalidated against the JWKS trust boundary. This occurs when a configured trusted JWKS endpoint returns an attacker-influenced redirect. As a result, PyJWKClient follows the redirect and consumes the redirected response as key ma...
CVE-2026-102271	New	7.4	HIGH				PyJWT is a Python implementation of JSON Web Token standards. From 2.4.0 until 2.14.0, PyJWT HMACAlgorithm.prepare_key is affected because asymmetric-key guard relies on textual markers that are absent from DER encoding. This occurs when an application mixes HMAC and asymmetric algorithms and supplies a DER public key as the shared verification key. As a result, PyJWT uses p...
CVE-2026-102272	New	7.4	HIGH				PyJWT is a Python implementation of JSON Web Token standards. From 2.13.0 until 2.14.0, HMACAlgorithm.prepare_key in jwt/algorithms.py is affected because raw-JWK detector does not normalize accepted Unicode byte-order marks before checking for JSON. This occurs when a public JWK is prefixed with a UTF-8 BOM and used in a mixed-algorithm verification path. As a result, publi...
CVE-2026-102273	New	7.4	HIGH				PyJWT is a Python implementation of JSON Web Token standards. From 2.13.0 until 2.14.0, PyJWT HMACAlgorithm.prepare_key is affected because HMAC key guard only recognizes top-level public JWK forms and misses container representations. This occurs when an application allows HMAC and asymmetric algorithms and passes a public JWK container as the raw key. As a result, public a...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102334	New	7.4	HIGH				Nginx Proxy Manager through 2.16.0 lacks rate-limiting on authentication endpoints, allowing unauthenticated attackers to make unlimited password guesses against any account. Attackers can brute-force login credentials via POST /api/tokens and subsequently guess TOTP codes via POST /api/tokens/2fa to gain full session access and administrative control.
CVE-2026-82375	New	7.4	HIGH				Server-Side Request Forgery (SSRF) in Apache Roller 6.1.5 allows an authenticated user with entry-editing rights on a weblog to cause outbound HTTP requests to attacker-chosen destinations through legacy outbound Trackback and entry enclosure handling. The Trackback control is hidden in the standard UI, but its action remains directly reachable; the enclosure path is relevan...
CVE-2026-101012	New	7.3	HIGH				A weakness has been identified in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbf3300d60c3494db3fb95b66e7be. This impacts an unknown function of the file makeresult.php. This manipulation of the argument makeid causes sql injection. The attack can be initiated remotely. The exploit has been made available to the public and could be used for attacks. Continious d...
CVE-2026-101015	New	7.3	HIGH				A flaw has been found in Trusted Domain Project OpenDMARC up to 1.4.2. Affected by this issue is some unknown functionality of the file policy.c of the component Domain Handler. Executing a manipulation can lead to improper validation of unsafe equivalence in input. The attack may be launched remotely. The exploit has been published and may be used. The vendor was contacted ...
CVE-2026-101066	New	7.3	HIGH				A vulnerability was determined in dbgate up to 7.3.1. The impacted element is the function createLink of the file packages/api/src/controllers/archive.js of the component Archive Link Creation. This manipulation of the argument linkedFolder causes path traversal. The attack may be initiated remotely. The exploit has been publicly disclosed and may be utilized. The vendor was...
CVE-2026-101067	New	7.3	HIGH				A vulnerability was identified in dbgate up to 6.8.1/7.0.2/7.1.8/7.2.5/7.3.1. This affects the function saveUploadedFile of the file files.js of the component save-uploaded-file Endpoint. Such manipulation of the argument filePath/fileName leads to path traversal. The attack may be launched remotely. The exploit is publicly available and might be used. The vendor was contact...
CVE-2026-101280	New	7.3	HIGH				A vulnerability was detected in Trusted Domain Project OpenDMARC up to 1.4.2. Affected is the function opendmarc_policy_query_dmarc of the component Multi-Record Set Handler. The manipulation results in authentication bypass by spoofing. The attack can be executed remotely. The exploit is now public and may be used. The vendor was contacted early about this disclosure but di...
CVE-2026-101281	New	7.3	HIGH				A flaw has been found in Trusted Domain Project OpenDMARC up to 1.4.2. Affected by this vulnerability is the function opendmarc_sp2_find_mailfrom_domain of the file libopendmarc/opendmarc_spf.c of the component SPF Macro Handler. This manipulation causes improper authentication. The attack is possible to be carried out remotely. The exploit has been published and may be used...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102245	New	7.3	HIGH				A weakness has been identified in MODSetter SurfSense up to 2.0.3. The affected element is an unknown function of the file <code>surfsense_backend/app/routes/circleback_webhook_route.py</code> of the component circleback Endpoint. Executing a manipulation can lead to missing authentication. The attack can be launched remotely. The exploit has been made available to the public and could b...
CVE-2026-102248	New	7.3	HIGH				A vulnerability was identified in Rebuild up to 4.4.7/4.5.0-beta5. This affects an unknown part of the file <code>/user/login</code> of the component Login Endpoint. The manipulation leads to improper authentication. It is possible to initiate the attack remotely. The exploit is publicly available and might be used. The vendor was contacted early about this disclosure but did not respond...
CVE-2026-102249	New	7.3	HIGH				A security flaw has been discovered in REBUILD up to 4.4.11. This vulnerability affects unknown code of the file <code>/commons/file-editor-save</code> . The manipulation of the argument <code>url/fileKey</code> results in missing authorization. It is possible to launch the attack remotely. The exploit has been released to the public and may be used for attacks. The vendor was contacted early about th...
CVE-2026-12267	New	7.2	HIGH				ManageEngine DDI Central versions below 6201 are vulnerable to Command injection in Windows DNS Query Resolution Policy name field leading to remote code execution.
CVE-2026-86330	New	7.2	HIGH				An OS command injection flaw was found in the <code>set_hostname_internal</code> function of NooBaa's <code>cluster_internal_api</code> . This component is responsible for managing the Multi-Cloud Object Gateway in OpenShift Data Foundation. The vulnerability occurs because the <code>hostname</code> parameter is passed directly to a shell command without proper sanitization. An authenticated attacker with administ...
CVE-2026-96326	New	7.2	HIGH				The HT Contact Form – Drag & Drop Form Builder for WordPress plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the Rich Text Editor Field in all versions up to, and including, 2.10.2 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute wh...
CVE-2026-101091	New	7.1	HIGH				SiYuan versions before v3.8.4 fail to properly validate SQL statements in block query embed blocks executed against <code>siyuan.db</code> . Attackers can craft malicious <code>.sy</code> documents with non-read-only SQL statements that execute automatically during background indexing, rendering, or export operations without authentication.
CVE-2026-102335	New	7.1	HIGH				Nginx Proxy Manager through 2.16.0 fails to restrict the <code>advanced_config</code> field to administrators, allowing non-admin users with manage permissions to inject arbitrary nginx directives. Attackers can inject malicious nginx configuration such as <code>alias</code> directives to serve arbitrary files or control routing for their assigned hosts.
CVE-2026-15952	New	7.1	HIGH				Incorrect Permission Assignment for Critical Resource vulnerability in ABB Protection and control IED manager (PCM600). This issue affects Protection and control IED manager (PCM600): through 2.14.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-52748	New	7.1	HIGH				The Kaon AR2140X router contains a vulnerability where the backup functionality is accessible without authentication. This allows an unauthenticated remote attacker to trigger a configuration backup and retrieve it in a form encrypted by a device-specific key. Triggering this function renders the router inoperable for a substantial period of time. This issue was identifi...
CVE-2026-55096	New	7.1	HIGH				fast-mcp-telegram is a Telegram MCP Server. Prior to version 30.1, the send_message/send_message_to_phone MCP tools accept files as a list of http(s) URLs, which the server downloads and attaches to the outgoing Telegram message. Downloads are guarded by _validate_url_security, an SSRF denylist that checks the URL's literal hostname string but never resolves DNS. The fetch (...
CVE-2026-87114	New	7.1	HIGH				A flaw was found in kube-compare. When processing a 'container://' reference path, the tool incorrectly executes an untrusted container image's entrypoint instead of merely extracting data from a stopped container. This allows a remote attacker to achieve arbitrary code execution on the operator's workstation. If the Docker daemon requires elevated privileges, the untrusted ...
CVE-2026-90925	New	7.1	HIGH				Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability in Innotim Software, Telecommunications and Consultancy Trade Ltd. Co. Logsign SIEM allows Path Traversal. This issue affects Logsign SIEM: from 6.4.101 before 6.4.117.
CVE-2026-93538	New	7.1	HIGH				A cross-tenant authorization issue was discovered in SUSE Rancher Fleet. During agent-initiated cluster registration, cluster labels supplied by the registering agent, including labels in the reserved management.cattle.io/ namespace such as the cluster display name label, were applied to the resulting upstream Cluster object. Because Fleet resolves GitRepo and Bundle targets...
CVE-2026-94286	New	7.1	HIGH				An out-of-bounds read in libXtst's RECORD reply parser in libXtst before 1.2.6 could be used by malicious X servers to crash attached X clients.
CVE-2026-97023	New	7.1	HIGH				A path traversal vulnerability in Flatpak's handling of the export/bin directory during app deployment allows a malicious Flatpak app to cause deletion of attacker-chosen files outside the deployment directory when the app is installed or upgraded. In system-wide installations, the deletion is performed as root.
CVE-2026-97024	New	7.1	HIGH				A path traversal vulnerability in Flatpak's handling of the files/etc directory during app deployment allows a malicious Flatpak app to cause certain host system files (such as passwd, group, machine-id, or resolv.conf) to be emptied or replaced with a symlink when the app is installed or upgraded. In system-wide installations, the write is performed as root.
CVE-2026-97685	New	7.1	HIGH				An authenticated LimeSurvey Community Edition 7.3.0 user allowed to create surveys can use their own survey as an authorized context while supplying question or answer identifiers belonging to another user's survey. The REST survey-patching endpoint checks the attacker's permission against the survey ID in the request URL, but the vulnerable persistence operations resolve th...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100392	New	7.0	HIGH				InvoicePlane is a self-hosted open source application for managing invoices, clients, and payments. In version 1.7.2, Users::form() performs no object-level authorization check on user_id = 1. A Secondary Administrator (user_type = 1, user_id != 1) can rewrite the Primary Administrator's user_type to 2 (Guest / read-only), destroying the root account's privilege and locking ...
CVE-2026-101898	New	7.0	HIGH				Axios is a promise-based HTTP client for the browser and Node.js. From 1.13.0 until 1.20.0, Axios HTTP/2 request setup does not consistently apply proxy settings and caller-supplied DNS lookup policy. An HTTPS request uses httpVersion: 2 with explicit config.proxy or environment-derived proxy settings, or relies on caller-supplied config.lookup DNS policy. The HTTP/2 path ca...
CVE-2026-101907	New	7.0	HIGH				Axios is a promise-based HTTP client for the browser and Node.js. From 1.17.0 until 1.20.0, the fetch adapter bypasses the maxRedirects: 0 redirect policy. An Axios request uses the fetch adapter with maxRedirects set to zero and receives a redirect response. The underlying fetch implementation follows the redirect instead of returning the redirect response unchanged. The re...
CVE-2026-102010	New	7.0	HIGH				A flaw was found in GCC. When an application calls the erase_if function on a binary heap priority queue in libstdc++, the library reallocates storage but fails to update its internal entry pointer. An attacker capable of triggering this operation can exploit this use-after-free condition, leading to a Denial of Service (DoS) via an application crash or potential memory corr...
CVE-2026-80357	New	7.0	HIGH				Dell Boot Optimized Server Storage (BOSS), versions prior to 2.2.13.2038, contains an On-Chip Debug and Test Interface With Improper Access Control vulnerability in the SMCU on 17G BOSS-N1 controllers. An unauthenticated attacker with physical access could potentially exploit this vulnerability, leading to Unauthorized access.
CVE-2026-101004	New	6.9	MEDI				A security vulnerability has been detected in notionnext-org NotionNext up to 4.10.10. Affected by this issue is the function cleanCache of the file pages/api/cache.js of the component Authentication Guard. The manipulation of the argument token leads to missing authentication. The attack may be initiated remotely. Versions 4.1.0 - 4.9.5.2 allow unauthenticated exploitation ...
CVE-2026-101083	New	6.9	MEDI				A security vulnerability has been detected in PMWeb v7.x/v8.x/v2025.x. Impacted is an unknown function in the library encryptionhelper.dll. Such manipulation leads to information disclosure. The attack may be launched remotely. The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-101900	New	6.9	MEDI				Axios is a promise-based HTTP client for the browser and Node.js. From 1.12.0 until 1.20.0, ResolveConfig reads inherited Symbol.toStringTag, append, and getHeaders properties while resolving FormData headers. A separate same-process prototype-pollution flaw supplies an array or non-plain class instance whose inherited properties make it appear FormData-like; plain objects a...
CVE-2026-101902	New	6.9	MEDI				Axios is a promise-based HTTP client for the browser and Node.js. From 0.27.2 until 0.34.0 and 1.20.0, Axios default-instance requests that omit an explicit method can read an inherited method value from Object.prototype. If another vulnerability in the same process pollutes Object.prototype.method, calls such as axios.request({ url }) and axios({ url }) can send a state-cha...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101904	New	6.9	MEDI				Axios is a promise-based HTTP client for the browser and Node.js. From 1.0.0 until 1.20.0, the dispatchRequest function normalizes inherited Object.prototype.headers from a replacement request configuration. A separate same-process prototype-pollution flaw sets Object.prototype.headers, and trusted request interceptors return a new ordinary configuration without an own heade...
CVE-2026-101908	New	6.9	MEDI				Axios is a promise-based HTTP client for the browser and Node.js. From 1.7.0 until 1.20.0, the fetch adapter constructs a Request with sanitized resolvedOptions but then calls fetch with the original fetchOptions. A separate same-process prototype-pollution flaw populates Object.prototype.headers so fetchOptions.headers resolves through inheritance. The inherited fetchOption...
CVE-2026-101910	New	6.9	MEDI			npm:ip-address	ip-address is a library for parsing and manipulating IPv4 and IPv6 addresses in JavaScript. From 10.2.0 until 10.5.1, the Address6 isPrivate classifier in src/ipv6.ts does not recognize the NAT64 local-use range 64:ff9b:1::/48. Applications that combine isPrivate, isLoopback, and isLinkLocal for a trust-boundary decision can treat an internal IPv4 destination encoded through...
CVE-2026-82935	New	6.9	MEDI				mH-DEVELOPER smart home module ships with an end-of-life, unsupported Debian 8 and Node.js runtime v17.0.1 in its production firmware. This exposes the device to publicly known vulnerabilities that will not receive security patches. An attacker could exploit these known flaws to execute arbitrary code, access sensitive data, or cause a denial of service on the device. Vulner...
CVE-2026-91154	New	6.9	MEDI				Missing Authentication for Critical Function (CWE-306) in the product cache revalidation Server Action (src/app/actions.ts, revalidateProducts) in MarcosCamara01 Ecommerce Template before commit ec97209 allows a remote, unauthenticated attacker to force expiration of the entire storefront product cache at will. The file declares "use server" at file scope, so every exported ...
CVE-2026-102247	New	6.8	MEDI				A vulnerability was detected in FastAdmin 1.6.1.20250430/1.6.5.20260602. This affects an unknown function of the file application/database.php of the component Database Management. The manipulation results in execution with unnecessary privileges. The attack may be launched remotely. The exploit is now public and may be used.
CVE-2026-18747	New	6.8	MEDI				The MCUmgr SMP-over-console transport decodes a base64 frame, reads a 16-bit packet length from it, verifies a CRC and then unconditionally strips the trailing CRC with rx_ctxt->nb->len -= 2U; in mcumgr_serial_process_frag() (subsys/mgmt/mcumgr/transport/src/serial_util.c). mcumgr_serial_extract_len() accepted any declared length, including 0 and 1, and a packet declaring le...
CVE-2026-80359	New	6.8	MEDI				Dell Boot Optimized Server Storage (BOSS), versions prior to 2.2.13.2038, contains an On-Chip Debug and Test Interface With Improper Access Control vulnerability in the SMCU on 17G BOSS-N1 controllers. An unauthenticated attacker with physical access could potentially exploit this vulnerability, leading to Unauthorized access.
CVE-2026-93000	New	6.8	MEDI				The SPS-Suite WordPress plugin through 1.4.0 does not sanitise the search query before using it in a SQL query when its static-page search feature is enabled, allowing unauthenticated attackers to perform SQL injection attacks.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2024-58386	New	6.5	MEDI				ZoneMinder versions 1.37.0 before 1.38.0 contain a path traversal vulnerability in the files view that allows authenticated users to read arbitrary files. The path parameter is not properly validated before being passed to output_file, enabling attackers with Events view permission to access sensitive files like configuration files containing database credentials.
CVE-2026-101040	New	6.5	MEDI				A security flaw has been discovered in Ricoh SP 330DN, SP 221, SP C252SF and Aficio SP 3500SF up to 20260813. This affects an unknown part of the component HTTP Multipart Form-Data Parser. Performing a manipulation results in denial of service. The attack is possible to be carried out remotely. The exploit has been released to the public and may be used for attacks. The vend...
CVE-2026-101277	New	6.5	MEDI				A security flaw has been discovered in Trusted Domain Project OpenDKIM up to 2.11.0. The impacted element is the function dkim_process_set of the file dkim.c of the component Tag Tokenizer. Performing a manipulation results in use of less trusted source. The attack may be initiated remotely. The exploit has been released to the public and may be used for attacks. The vendor ...
CVE-2026-101279	New	6.5	MEDI				A security vulnerability has been detected in Trusted Domain Project OpenDMARC up to 1.4.2. This impacts an unknown function of the file libopendmarc/opendmarc_policy.c of the component DMARC Parser. The manipulation of the argument pct leads to integer overflow. Remote exploitation of the attack is possible. The exploit has been disclosed publicly and may be used. The vendo...
CVE-2026-101914	New	6.5	MEDI			npm:@grpc/grpc-js-xds	@grpc/grpc-js implements the core functionality of gRPC purely in JavaScript, without a C++ addon. Prior to 1.13.1 and 1.14.1, the exact path (method name) matcher used by RBAC performs a prefix comparison instead of an equality comparison when case-insensitive matching is enabled. If one service method name prefixes another and the methods have different access rules, a req...
CVE-2026-102275	New	6.5	MEDI				PyJWT is a Python implementation of JSON Web Token standards. From 2.1.0 until 2.15.0, PyJWT OKPAlgorithm.from_jwk in jwt/algorithms.py is affected because private-JWK import path does not compare the public key derived from d with x. This occurs when an OKP private JWK supplies non-corresponding x and d components. As a result, identity derived from x can differ from opera...
CVE-2026-102296	New	6.5	MEDI				ZoneMinder before 1.38.4 contains static buffer overflow vulnerabilities in RemoteCameraHttp::GetResponse() that allow malicious HTTP cameras or intercepting attackers to overflow fixed-size buffers by sending oversized response headers. Attackers can send crafted HTTP responses with oversized status messages, Connection headers, Content-Type values, or multipart boundaries ...
CVE-2026-102365	New	6.5	MEDI				mall4j through 4.0 fails to enforce authorization checks on GET endpoints in UserAddrController that retrieve customer address data. Authenticated attackers can call /user/addr/page and /user/addr/info endpoints to harvest all customer addresses including names, phone numbers, and postal information.
CVE-2026-102373	New	6.5	MEDI				GestSup versions before 3.2.62 fail to validate ticket ownership when loading comments via the threadedit parameter in thread.php. Authenticated attackers can enumerate sequential comment IDs to read private comments from other users' tickets without proper authorization checks.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-18417	New	6.5	MEDI				The native BSD-socket layer recorded a pending asynchronous socket error by type-punning it into struct net_context's void user_data field (ctx->user_data = INT_TO_POINTER(-status) in zsock_accepted_cb(), zsock_received_cb(), zsock_connected_cb() and zsock_close_ctx() in subsys/net/lib/sockets/sockets_inet.c), reading it back with POINTER_TO_INT(). That same field is owned b...
CVE-2026-19444	New	6.5	MEDI				A path traversal vulnerability was discovered in the Kubernetes kubectrl client's kubectrl cp command on Windows. When copying files from a container, kubectrl runs tar inside the container to build a tar archive, transfers it over the network, and unpacks it on the local machine. If the tar binary in the container is malicious, it can execute arbitrary code and emit unexpected...
CVE-2026-82385	New	6.5	MEDI				Exposure of Sensitive Information to an Unauthorized Actor in Apache Roller 6.1.5 allows a weblog administrator to read files on the application classpath, including Roller configuration files containing secrets, by authoring a Velocity template that uses an include directive to load a classpath resource outside the theme namespace. Roller treats weblog administrators as unt...
CVE-2026-82915	New	6.5	MEDI				Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability in Bimser Solution Software Trade Inc. EBA Plus Document and Workflow Management System allows Path Traversal. This issue affects eBA Plus Document and Workflow Management System: from 6.7.141 before 10.0.11.
CVE-2026-84744	New	6.5	MEDI				The WPForms Lite WordPress plugin from 1.5.0.1 to 2.0.2 does not remove shortcode delimiters from submitted field values before writing them back into the rendered form, allowing unauthenticated users to execute arbitrary shortcodes registered on the site and read the details of attachments belonging to non-public posts.
CVE-2026-93537	New	6.5	MEDI				A user who can supply bundle content to a repository referenced by a GitRepo resource, for example through Git push access, or through permission to create or modify a GitRepo, can cause SUSE Rancher Fleet to read files from the filesystem of the environment that processes the bundle and include their contents in the generated Bundle resource. This can expose configuration o...
CVE-2026-93540	New	6.5	MEDI				A privilege mismatch was found in Fleet. When a bundle requested namespace labels or annotations through the namespaceLabels and namespaceAnnotations options, the resulting namespace metadata update was not subject to the same authorization as the rest of the bundle's deployment. As a result, a bundle could change labels and annotations on a target namespace even when the id...
CVE-2026-94283	New	6.5	MEDI				An out-of-bounds read vulnerability in libX11's XIM (X Input Method) attribute parser in libX11 before 1.8.14 could be used by malicious X servers to crash attached X clients.
CVE-2026-96740	New	6.5	MEDI				A flaw was found in the StreamsHub Console for Apache Kafka. Tenant-supplied Kafka client properties from the Console custom resource are copied into the console-api AdminClient configuration without filtering security-sensitive keys, allowing a Console CR author to set config.providers and bootstrap.servers to exfiltrate the console-api ServiceAccount token to an attacker-c...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82930	New	6.4	MEDI				mH-DEVELOPER smart home module does not verify tokens in its authorization middleware, leaving all HTTP API and WebSocket endpoints accessible without authentication. An unauthenticated attacker on the LAN can query these endpoints, access system information, and send raw control commands to manipulate building automation devices. This issue was fixed in version 3.0.30
CVE-2026-89303	New	6.4	MEDI				The Post Voting System WordPress plugin through 1.0 does not properly sanitize and escape a parameter before using it in a SQL query, allowing any authenticated user to perform SQL injection attacks.
CVE-2026-101102	New	6.3	MEDI				A vulnerability was found in deepseek-ai deepseek-harness up to 0.1.0-rc.7. Impacted is the function run_code of the component Code Mode Sandbox. The manipulation results in sandbox issue. The attack can be executed remotely. The vendor's own code, SAFETY.md, and design notes all explicitly state the worker is "containment, not a security boundary". The vendor was contacted ...
CVE-2026-101105	New	6.3	MEDI				A vulnerability was determined in code-projects Matrimonial System 1.0. The affected element is the function processprofile_form of the file /create_profile of the component Profile Creation Endpoint. This manipulation of the argument frame causes sql injection. The attack is possible to be carried out remotely. The exploit has been publicly disclosed and may be utilized.
CVE-2026-101142	New	6.3	MEDI				A vulnerability has been found in Eleveo Quality Management 9.7.0. Affected by this vulnerability is an unknown functionality of the file Scorecard.jsp of the component Questionnaire Audio Upload. The manipulation leads to path traversal. The attack may be initiated remotely. The exploit has been disclosed to the public and may be used. The vendor was contacted early about t...
CVE-2026-101144	New	6.3	MEDI				A vulnerability was determined in Eleveo Call Recording Software 9.7.0. This affects an unknown part of the file /callrec/searchAction.do of the component Query Builder. This manipulation causes improper access controls. Remote exploitation of the attack is possible. The exploit has been publicly disclosed and may be utilized. The vendor was contacted early about this disclo...
CVE-2026-101202	New	6.3	MEDI				A flaw has been found in FastStone Image Viewer up to 8.3. The affected element is an unknown function of the component TGA Image Handler. Executing a manipulation can lead to out-of-bounds write. It is possible to launch the attack remotely. The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-101203	New	6.3	MEDI				A vulnerability has been found in FastStone Image Viewer up to 8.3. The impacted element is an unknown function of the component 1bpp RLE Decoder. The manipulation leads to out-of-bounds write. The attack can be initiated remotely. The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-101204	New	6.3	MEDI				A vulnerability was found in FastStone Image Viewer up to 8.3. This affects an unknown function of the file FSViewer.exe of the component TGA Image Handler. The manipulation results in out-of-bounds read. The attack can be launched remotely. The vendor was contacted early about this disclosure but did not respond in any way.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101205	New	6.3	MEDI				A vulnerability was determined in FastStone Image Viewer up to 8.3. This impacts an unknown function of the component PCX Decoder. This manipulation causes out-of-bounds read. The attack may be initiated remotely. The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-101911	New	6.3	MEDI				ip-address is a library for parsing and manipulating IPv4 and IPv6 addresses in JavaScript. Prior to 10.7.1, the Address6 constructor, Address6.isValid, and parse code in src/ipv6.ts accept unbounded strings and expand invalid characters through RE_BAD_CHARACTERS into large diagnostics. Material impact occurs only when an application accepts a very large attacker-controlled ...
CVE-2026-101912	New	6.3	MEDI				ip-address is a library for parsing and manipulating IPv4 and IPv6 addresses in JavaScript. Prior to 10.7.1, the isInSubnet and isHostInSubnet methods in src/common.ts compare masked binary strings without validating that both operands use the same IP family. A cross-family containment check whose leading address bits match makes the masked strings compare equal even though ...
CVE-2026-101913	New	6.3	MEDI			npm:ip-address	ip-address is a library for parsing and manipulating IPv4 and IPv6 addresses in JavaScript. Prior to 10.5.1, the Address6 isLinkLocal method in src/ipv6.ts recognizes only fe80::/64 instead of the complete fe80::/10 IPv6 link-local range. An attacker-controlled address elsewhere in fe80::/10 can therefore pass a trust-boundary check that relies on isLinkLocal. The same addre...
CVE-2026-102414	New	6.3	MEDI				pbkdf2 through 3.1.6 re-hashes passwords longer than the digest's block size on every iteration in its JavaScript fallback (lib/sync.js). A password longer than the block size (64 bytes, or 128 bytes for sha384 and sha512) is passed to HMAC as the key on every iteration, and HMAC hashes such keys in full each time. Cost is therefore O(iterations × password length), and a lon...
CVE-2026-18415	New	6.3	MEDI				ieee802154_send() in subsys/net/l2/ieee802154/ieee802154.c copies the outgoing packet into a single fixed 125-byte transmit buffer (tx_frame_buf_pool, sized IEEE802154_MTU). In builds with CONFIG_NET_L2_IEEE802154_FRAGMENT enabled (the default whenever CONFIG_NET_6LO is set), the branch taken when 6LoWPAN fragmentation is not required performed an unchecked net_buf_add_mem(f...
CVE-2026-82929	New	6.3	MEDI				mH-DEVELOPER smart home module uses the same hard-coded SSH host keys on every device, with no per-device key generation. An attacker who extracts these keys from the firmware can set up a rogue SSH server that clients will trust without warning, enabling man-in-the-middle attacks and credential interception. This issue was fixed in version 3.0.30
CVE-2026-86335	New	6.3	MEDI				Missing Authorization in imageDownload in Canonical LXD before 5.0.10, 5.21.8, and 6.10 on Linux allows a project-restricted client to access private images from other projects via local fingerprint reuse during image or instance import requests.
CVE-2026-92103	New	6.3	MEDI				Allocation of Resources Without Limits or Throttling vulnerability in elixir-mint mint allows a malicious HTTP/2 server to make the client hold up to about 16 MiB per connection in frames it should reject, consuming client memory. Mint.HTTP2.Frame.decode_next/2 in lib/mint/http2/frame.ex compares a frame with the client's max_frame_size (16,384 bytes by default) only once t...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94194	New	6.3	MEDI				Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling') vulnerability in elixir-mint mint allows a malicious HTTP/1 server to desynchronize an intermediary and the Mint client on a pooled connection, poisoning the responses to subsequent requests that share the connection. message_body/1 in lib/mint/http1.ex selects chunked framing when chunked is t...
CVE-2026-102332	New	6.1	MEDI				Dozzle versions before 11.1.2 fail to sanitize container display names when building ZIP archive entry names in the log download endpoint. Attackers who can label containers can use path traversal sequences to write files outside the extraction directory when users download and extract logs.
CVE-2026-102333	New	6.1	MEDI				httplib before 2.2.1 fails to validate URL schemes in recorded HTTP request URLs rendered as clickable links in the web interface. Attackers controlling traffic recorded by httplib can supply javascript: scheme URLs that execute malicious scripts in the application origin when clicked, allowing access to captured request and response data including headers and tokens.
CVE-2026-102372	New	6.1	MEDI				GestSup versions before 3.2.62 fail to properly sanitize HTML email bodies in the IMAP LOGIN connector, allowing unauthenticated attackers to store arbitrary JavaScript in ticket descriptions and replies. Attackers can send emails to the monitored mailbox containing script tags and event handlers that execute in technician browsers, enabling ticket data theft and unauthorize...
CVE-2026-102374	New	6.1	MEDI				GestSup versions before 3.2.62 contain a stored cross-site scripting vulnerability in the IMAP OAuth connector that double-decodes MIME-encoded email subjects after HTML escaping. Unauthenticated attackers can send crafted emails to monitored mailboxes with nested MIME encoded-words to inject JavaScript that executes in technician sessions when viewing tickets.
CVE-2026-82382	New	6.1	MEDI				Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') in Apache Roller 6.1.5 allows a remote attacker to perform reflected cross-site scripting against a visitor to a weblog using the bundled frontpage theme, by supplying a crafted blog-directory parameter that the directory page reflects without proper escaping. This affects only weblogs that ...
CVE-2026-82546	New	6.1	MEDI				Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') in Apache Roller 6.1.5 allows an unauthenticated remote attacker to store a crafted comment-author URL through the incoming Trackback endpoint when a published entry accepts comments and Trackbacks. The shipped Trackback, verification and moderation defaults allow the value to be approved an...
CVE-2026-86507	New	6.1	MEDI				Improper neutralization of input in Apache Roller 6.1.5 allows an anonymous remote attacker to store a crafted comment-author URL that can execute script in the session of a weblog moderator or global administrator when the comment management page is viewed. This affects sites that permit comments on at least one weblog and whose moderator subsequently reviews the submitted ...
CVE-2026-87752	New	6.1	MEDI				Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in Rolantis Information Technologies Tourism Industry and Trade Co. Ltd. Agentis allows XSS Targeting HTML Attributes. This issue affects Agentis: from 4.44 before 4.6.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91204	New	6.1	MEDI				Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') in Apache Roller 6.1.5 allows an anonymous remote attacker to store a comment containing a javascript: URI link that survives HTML comment formatting and can execute script in the browser of a visitor who clicks it. This affects only sites that enable HTML in comments (users.comments.htmlena...
CVE-2026-91206	New	6.1	MEDI				Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') in Apache Roller 6.1.5 allows a remote attacker to perform reflected cross-site scripting through the optional LDAP comment authenticator, which writes request parameter values into its HTML form without escaping. This affects only sites configured to use LdapCommentAuthenticator, and a vict...
CVE-2026-82933	New	6.0	MEDI				mH-DEVELOPER smart home module sends its web interface and API traffic over unencrypted HTTP. Passwords, authentication tokens, and device commands are transmitted in cleartext. An attacker on the same network can intercept this traffic, steal credentials and tokens, and hijack sessions. This issue was fixed in version 3.0.30
CVE-2026-102274	New	5.9	MEDI				PyJWT is a Python implementation of JSON Web Token standards. From 2.9.0 until 2.14.0, PyJWKSet does not catch the plain ValueError raised for malformed RSA JWK components by RSAAAlgorithm.from_jwk in jwt/api_jwk.py. This occurs when a JWK Set contains a malformed RSA key alongside otherwise usable keys. As a result, one malformed member aborts construction of the entire PyJ...
CVE-2026-18746	New	5.9	MEDI				parse_write_op() in subsys/net/lib/lwm2m/lwm2m_message_handling.c handles inbound CoAP WRITE/CREATE requests that carry a Block1 option. For the first block of a transfer it called init_block_ctx() and then immediately stored the peer-selected block size with block_ctx->ctx.block_size = block_size before inspecting the return code. init_block_ctx() sets the caller's pointer ...
CVE-2026-82936	New	5.9	MEDI				mH-DEVELOPER smart home module is vulnerable to Denial of Service due to uncontrolled resource consumption. The Express bodyParser is configured with a 250 MB limit for JSON and URL-encoded request bodies. An authenticated attacker on the LAN can send large request bodies that exhausts buffers in RAM, causing out-of-memory conditions and crashing the fh-node process, resulti...
CVE-2026-87798	New	5.8	MEDI				Improper link resolution in the recursive file pull feature of the LXD CLI client in Canonical LXD versions 4.0.2 up to 6.9 (fixed in 4.0.14, 5.0.10 and 5.21.8) on Linux allows an attacker with root access inside a virtual machine to write attacker-controlled files or directory trees to arbitrary paths on the client host, with the operator's privileges. The attacker does thi...
CVE-2026-97029	New	5.7	MEDI				Flatpak's process ID namespace separation does not prevent a sandboxed app's kill(0, signal) or killpg(0, signal) calls from reaching processes outside the sandbox that share the same process group. A malicious or compromised Flatpak app can use this to cause denial of service by terminating processes outside its sandbox, such as the desktop shell.
CVE-2026-15953	New	5.6	MEDI				Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability in ABB Protection and control IED manager (PCM600). This issue affects Protection and control IED manager (PCM600): through 2.14.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-70413	New	5.6	MEDI				Dell Live Optics Collector, versions prior to 27.2.13.310, contain(s) a Use of Hard-coded Password vulnerability. A low privileged attacker with local access could potentially exploit this vulnerability, leading to Information exposure.
CVE-2026-94282	New	5.6	MEDI				An out-of-bounds read in libXi's X12 enter/leave/focus cookie conversion in libXi before 1.8.4 could be used by malicious X server to crash an attached X client.
CVE-2026-101005	New	5.5	MEDI				A vulnerability was detected in October CMS up to 4.3.4. This affects the function validateExternalImageHost of the file System/Classes/ResizeImages.php of the component SSRF Protection. The manipulation results in server-side request forgery. The attack may be launched remotely. The exploit is now public and may be used. Upgrading to version 4.3.5 is able to mitigate this i...
CVE-2026-101013	New	5.5	MEDI				A security vulnerability has been detected in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbfbf3300d60c3494db3fb95b66e7be. Affected is an unknown function of the file updateresultdetails.php. Such manipulation of the argument editid leads to sql injection. The attack can be launched remotely. The exploit has been disclosed publicly and may be used. This product do...
CVE-2026-101014	New	5.5	MEDI				A vulnerability was detected in Trusted Domain Project OpenDMARC up to 1.4.2. Affected by this vulnerability is the function opendmarc_util_cleanup in the library libopendmarc/opendmarc_util.c of the component DMARC Record Parser. Performing a manipulation results in off-by-one. The attack may be initiated remotely. The exploit is now public and may be used. The patch is nam...
CVE-2026-101016	New	5.5	MEDI				A vulnerability has been found in Trusted Domain Project OpenDMARC up to 1.4.2. This affects the function opendmarc_policy_parse_dmarc in the library libopendmarc/opendmarc_policy.c. The manipulation of the argument fo/rt/ri/pct/sp/adkim/aspf/rua/ruf leads to handling of exceptional conditions. Remote exploitation of the attack is possible. The exploit has been disclosed to ...
CVE-2026-101017	New	5.5	MEDI				A vulnerability was found in Trusted Domain Project OpenDMARC up to 1.4.2. This vulnerability affects the function strcasecmp in the library libopendmarc/opendmarc_policy.c. The manipulation results in handling of exceptional conditions. The attack can be executed remotely. The exploit has been made public and could be used. The vendor was contacted early about this disclosu...
CVE-2026-101035	New	5.5	MEDI				A flaw has been found in aligungr UERANSIM up to 3.3.0. This affects the function DecodePlainMmMessage in the library src/lib/nas/encode.cpp of the component nr-gnb. Executing a manipulation can lead to uncaught exception. The attack can be launched remotely. The exploit has been published and may be used. This patch is called 1ae9bf2062b57595dbcb4bc1d0a0ccf06815bac. It is ...
CVE-2026-101052	New	5.5	MEDI				A security vulnerability has been detected in reflly-ai reflly up to 1.1.0. This issue affects some unknown processing of the file apps/api/src/modules/config/app.config.ts of the component JWT Token Handler. The manipulation with the input test leads to hard-coded credentials. It is possible to initiate the attack remotely. The exploit has been disclosed publicly and may be u...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101053	New	5.5	MEDI				A vulnerability was determined in Thinkware U3000 up to 1.02.04. This impacts the function PUT_FILE of the file /tmp/wpa_supplicant.conf of the component TCP Service. Executing a manipulation of the argument path can lead to improper access controls. The attack may be launched remotely. The exploit has been publicly disclosed and may be utilized. The vendor was contacted ear...
CVE-2026-101055	New	5.5	MEDI				A security flaw has been discovered in Thinkware U3000 up to 1.02.04. Affected by this vulnerability is the function GET_STATUS of the component TCP Service. The manipulation of the argument wifi_info results in information disclosure. The attack can be executed remotely. The exploit has been released to the public and may be used for attacks. The vendor was contacted early ...
CVE-2026-101068	New	5.5	MEDI				A security flaw has been discovered in dbgate up to 7.3.1. This impacts the function zipJsonLinesData of the file packages/api/src/utility/zipJsonLinesData.js of the component Create Connection Endpoint. Performing a manipulation of the argument filePath results in path traversal. Remote exploitation of the attack is possible. The exploit has been released to the public and ...
CVE-2026-101069	New	5.5	MEDI				A weakness has been identified in dbgate up to 7.3.1. Affected is the function exportModelSql of the file packages/api/src/controllers/databaseConnections.js of the component Export Handler. Executing a manipulation of the argument outputFile can lead to path traversal. The attack can be executed remotely. The exploit has been made available to the public and could be used f...
CVE-2026-102005	New	5.5	MEDI				Wind River VxWorks 7 24.03 through 26.03, a memory leak occurs under specific, non-default configuration states when processing specific service routines, causing the system to terminate operations before releasing allocated memory pools. Fixed in VxWorks 7 26.09
CVE-2026-102006	New	5.5	MEDI				In Wind River VxWorks 7 prior to 26.09, specific system call arguments can result in the process management subsystem failing to properly release allocated kernel memory before terminating the calling application. Fixed in Version 26.09
CVE-2026-94284	New	5.5	MEDI				An out-of-bounds read vulnerability in libX11's XIM trigger-key registration parser in libX11 before 1.8.14 could be used by malicious X servers to crash attached X clients.
CVE-2026-94287	New	5.5	MEDI				A denial of service via unsigned underflow in libXpm's write path in libXpm before 3.5.19 could be used by local attackers to cause unbounded CPU usage and memory exhaustion.
CVE-2026-97686	New	5.5	MEDI				Wind River VxWorks 7 prior to 26.09, specific system call arguments can result in the IPNET subsystem failing to properly release allocated kernel memory and system file descriptors before terminating the calling application. Fixed in Version 26.09.
CVE-2026-101093	New	5.4	MEDI				Cotonti through 1.0.0 contains a cross-site request forgery vulnerability in admin.users.php that allows attackers to delete user groups without token verification. Attackers can craft malicious links or pages that trick authenticated administrators into deleting custom groups and their associated permissions by riding the administrator's session.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101100	New	5.4	MEDI				A flaw has been found in ag-ui-protocol ag-ui up to 2026-09-07. This vulnerability affects the function FilterToolCallsMiddleware of the file <code>sdk/typescript/packages/client/src/middleware/filter-tool-calls.ts</code> of the component Middleware. Executing a manipulation can lead to incomplete cleanup. The attack may be launched remotely. Upgrading to version 2026-09-08 is able to r...
CVE-2026-101859	New	5.4	MEDI				A vulnerability has been found in RaspAP raspap-webgui up to 3.5.5. Affected by this vulnerability is the function escapeshellcmd of the file <code>ajax/openvpn/del_ovpnconf.php</code> of the component OpenVPN Configuration Handler. Such manipulation of the argument <code>cfg_id</code> leads to os command injection. The attack can be launched remotely. The exploit has been disclosed to the public and ...
CVE-2026-102261	New	5.4	MEDI				A flaw has been found in owen2345 Camaleon CMS up to 2.9.2. Impacted is the function crop of the file <code>app/controllers/camaleon_cms/admin/media_controller.rb</code> of the component Media Crop Handler. This manipulation of the argument <code>saved_avatar</code> causes authorization bypass. The attack may be initiated remotely. The exploit has been published and may be used. Upgrading to version ...
CVE-2026-102364	New	5.4	MEDI				mall4j through 4.0 fails to validate the <code>sysType</code> field in <code>sa-token</code> sessions, allowing storefront customers to authenticate as back-office users by reusing their session tokens. Attackers can register on the public storefront and use their customer session token to access admin endpoints lacking <code>@PreAuthorize</code> permission checks, including menu listings, file uploads, and confi...
CVE-2026-102367	New	5.4	MEDI				mall4j through 4.0 contains an insufficient session expiration vulnerability in the token refresh endpoint that fails to validate the <code>enabled</code> flag when issuing new sessions. Disabled user accounts can indefinitely renew their sessions through the <code>POST /token/refresh</code> endpoint, retaining access that account disabling was intended to remove.
CVE-2026-82381	New	5.4	MEDI				Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') in Apache Roller 6.1.5 allows a user with authoring rights on a weblog to store crafted content that is later written into the authoring UI's JavaScript string literals and markup sinks without proper encoding, causing the stored script to execute in another author's or administrator's brows...
CVE-2026-82387	New	5.4	MEDI				Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') in Apache Roller 6.1.5 allows a user with media-upload rights to store active content on Roller's origin, because the media upload feature trusts the upload-supplied content type and serves the stored file back with that type. A victim who opens the uploaded file executes the stored script. ...
CVE-2026-82969	New	5.4	MEDI				Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in Bimser Solution Software Trade Inc. EBA Plus Document and Workflow Management System allows Stored XSS. This issue affects eBA Plus Document and Workflow Management System: from 6.7.141 before 10.0.11.
CVE-2026-88828	New	5.4	MEDI				The Blacklist Manager for WooCommerce WordPress plugin from 1.3.0 to 2.3.1 does not enforce its user blocking on every authentication path, allowing the holder of an account the site owner has blocked to keep authenticating with that account's privileges, without the block being enforced or recorded.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93539	New	5.4	MEDI				A vulnerability was discovered in Fleet's Git webhook receiver (the gitjob webhook service). When a webhook secret is not configured, incoming webhook requests are accepted without verification, and processing a request can change the spec.pollingInterval field of a matching GitRepo resource in any namespace. A caller with network access to the webhook service and no Kuberne...
CVE-2026-100753	New	5.3	MEDI				Joomla Extension - ordasoft.com - Reflected Cross-Site Scripting in Real Estate Manager (Free) < 6.7.9 - The public property-detail page's "leave a review" form repopulates its title field directly from the request with no escaping and no filtering function of any kind, unlike the adjacent comment field on the same form, which at least receives partial tag-stripping. A " ch...
CVE-2026-101003	New	5.3	MEDI				A weakness has been identified in Cesanta Mongoose up to 7.21. Affected by this vulnerability is the function fn of the file tutorials/mqtt/mqtt-server/main.c of the component MQTT Broker. Executing a manipulation can lead to stack-based buffer overflow. The attack can be launched remotely. The exploit has been made available to the public and could be used for attacks. Upgr...
CVE-2026-101054	New	5.3	MEDI				A vulnerability was identified in Thinkware U3000 up to 1.02.04. Affected is the function get_file of the file /tmp/wpa_suppllicant.conf of the component TCP Service. The manipulation leads to improper access controls. Remote exploitation of the attack is possible. The exploit is publicly available and might be used. The vendor was contacted early about this disclosure but di...
CVE-2026-101070	New	5.3	MEDI				A security vulnerability has been detected in dbgate up to 7.3.1. Affected by this vulnerability is the function files of the file packages/api/src/controllers/runners.js of the component Files Endpoint. The manipulation of the argument runid leads to path traversal. The attack is possible to be carried out remotely. The exploit has been disclosed publicly and may be used. T...
CVE-2026-101082	New	5.3	MEDI				A weakness has been identified in PMWeb 7.x/8.x/2025.x. This issue affects some unknown processing of the file downloader.aspx. This manipulation of the argument FullFileName/FileName causes path traversal. The attack may be initiated remotely. The exploit has been made available to the public and could be used for attacks. The vendor was contacted early about this disclosur...
CVE-2026-101092	New	5.3	MEDI				SiYuan before v3.8.4 fails to enforce publish-access checks in the getCurrentAttrViewImages endpoint, allowing publish readers to retrieve image asset paths from unauthorized databases. Attackers can call the endpoint with an unrendered database identifier obtained through related endpoints to leak detached-row image asset paths and filenames that the rendering endpoint woul...
CVE-2026-101098	New	5.3	MEDI				A security vulnerability has been detected in ag-ui-protocol ag-ui up to 2026-09-23. Affected by this issue is the function readAllBytes of the file JdkAgentHttpHandler.java of the component HTTP Handler. Such manipulation leads to resource consumption. The attack can be launched remotely. The pull request to fix this issue awaits acceptance.
CVE-2026-101101	New	5.3	MEDI				A vulnerability has been found in ag-ui-protocol ag-ui up to 2026-09-07. This issue affects the function JSON.parse of the file legacy/convert.ts of the component Middleware. The manipulation leads to uncaught exception. Remote exploitation of the attack is possible. Upgrading to version 2026-09-08 is capable of addressing this issue. The identifier of the patch is 30f8c794d...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101109	New	5.3	MEDI				Joomla Extension - ordasoft.com - Reflected Cross-Site Scripting in Vehicle Manager (Free) < 6.5.8 - The public vehicle-detail page (task=view) echoes the title request parameter directly into a double-quoted HTML attribute with no output encoding of any kind. A double-quote character in the parameter closes the attribute, allowing arbitrary markup, including a <script> tag,...
CVE-2026-101111	New	5.3	MEDI				Joomla Extension - ordasoft.com - Reflected Cross-Site Scripting in Book Library (Free) < 6.4.6 - The public book-detail page template, site/views/view_book/tmpl/default.php, echoes the raw title request parameter directly into a double-quoted HTML attribute with no escaping function of any kind (echo \$_REQUEST["title"]);. A value containing a double quote closes the attribu...
CVE-2026-101917	New	5.3	MEDI				PyJWT is a Python implementation of JSON Web Token standards. Prior to 2.14.0, PyJWT get_signing_key_from_jwt is affected because unknown kid misses force refreshes without a negative cache or minimum refresh interval. This occurs when unauthenticated tokens repeatedly use the same unknown kid or varying kid values absent from the cached JWKS. As a result, each cache miss ca...
CVE-2026-101918	New	5.3	MEDI				PyJWT is a Python implementation of JSON Web Token standards. From 2.0.0a1 until 2.15.0, PyJWT PyJWKClient.get_signing_key_from_jwt is affected because payload parser catches ValueError but not RecursionError. This occurs when an attacker-controlled recursively nested payload reaches json.loads. As a result, documented PyJWT exception handling does not contain the failure. C...
CVE-2026-102265	New	5.3	MEDI				PyJWT is a Python implementation of JSON Web Token standards. From 2.13.0 until 2.14.0, PyJWS._load in jwt/api_jws.py is affected because parser catches ValueError but not RecursionError. This occurs when a deeply nested token header reaches json.loads. As a result, RecursionError escapes the documented PyJWT error hierarchy. Consequently, an unauthenticated malformed token ...
CVE-2026-102277	New	5.3	MEDI				The brace-expansion library generates arbitrary strings containing a common prefix and suffix. Prior to 1.1.21, 2.1.7, 3.0.9, and 5.0.12, the expand function handles untrusted {a},b)-shaped patterns with many trailing closing braces by restarting its scan once for each trailing closing brace. The successive full-input rescans with linear working-string growth cause quadratic...
CVE-2026-102362	New	5.3	MEDI				mall4j through 4.0 fails to implement authentication controls on the DELETE /prodComm endpoint in ProdCommController. Unauthenticated attackers can delete arbitrary product reviews by supplying the prodCommId parameter without authorization checks.
CVE-2026-18825	New	5.3	MEDI				An Origin Validation Error in the middleware of the connect-xcors npm package allows an attacker to bypass origin verification and perform a cross domain authenticated request.
CVE-2026-52749	New	5.3	MEDI				The Kaon AR2140X router improperly issues session cookies in responses to unauthenticated HTTP requests. This vulnerability allows a remote attacker to obtain a valid session identifier without providing credentials, resulting in an authentication bypass. With this access, the attacker can perform unauthorized actions on upgrade-related functionalities. These actions can be ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-55156	New	5.3	MEDI				Token Optimizer MCP measures token savings per AI coding agent, optimizes context, and shares a live local knowledge graph across 16 CLI clients. Prior to version 5.1.0, the dashboard HTTP server in token-optimizer-mcp exposes /api/session-summary and /api/session-events with no authentication middleware — any network-accessible client can reach them without credentials. Bot...
CVE-2026-82932	New	5.3	MEDI				mH-DEVELOPER smart home module does not load any firewall rules at startup. This leaves all listening services, including SSH, HTTP, WebSocket, and Node-RED, fully exposed on the LAN without access control. Any client on the same network can reach every service. This issue was fixed in version 3.0.30
CVE-2026-86838	New	5.3	MEDI				The Bookly WordPress plugin before 28.3 does not validate client-supplied booking quantity values on the server before computing the appointment total, allowing unauthenticated users to reduce the total to zero and book paid services for free while bypassing the payment step.
CVE-2026-89300	New	5.3	MEDI				The WP Verify API WordPress plugin through 1.0.0 does not have any authorisation check in one of its REST routes, allowing unauthenticated users to insert arbitrary data into its own database table, as well as to make the site send templated verification emails to arbitrary email addresses. The route is not rate limited either.
CVE-2026-89411	New	5.3	MEDI				The Paymattic WordPress plugin from 4.6.20 before 4.6.26 does not verify that a confirmed Stripe payment belongs to the order it is applied to, allowing unauthenticated users to mark an arbitrary pending order as paid by confirming a smaller payment of their own against it.
CVE-2026-92996	New	5.3	MEDI				The Verge3D WordPress plugin from 4.1.0 through 4.13.0 does not verify with the payment provider that a payment was actually made, and does not check order ownership, allowing unauthenticated users to mark any order as paid.
CVE-2026-73641	New	5.1	MEDI				Dayforce Payroll is vulnerable to Reflected XSS in multiple endpoints. An attacker can prepare a specially crafted URL that, when opened, results in arbitrary JavaScript execution in the victim's browser. Because vendor contact attempts were unsuccessful, the vulnerability has only been confirmed in version R2026.2.0 but may also affect other versions.
CVE-2026-80358	New	5.1	MEDI				Dell Boot Optimized Server Storage (BOSS), versions prior to 2.2.13.2038, contains an On-Chip Debug and Test Interface With Improper Access Control vulnerability in the SMCU on 17G BOSS-N1 controllers. An unauthenticated attacker with physical access could potentially exploit this vulnerability, leading to Unauthorized access.
CVE-2026-94285	New	5.1	MEDI				An out-of-bounds read in libX11's byte-oriented codeset parser in libX11 before 1.8.14 could be used by malicious X servers to crash attached X clients.
CVE-2026-102269	New	4.8	MEDI				PyJWT is a Python implementation of JSON Web Token standards. Prior to 2.14.0, PyJWT signature segment is affected because signature segment decoding accepts characters outside the canonical Base64URL representation. This occurs when non-Base64URL characters are appended to a valid compact JWS signature segment. As a result, base64url_decode produces the same signature bytes...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-7170	New	4.8	MEDI				Stored Cross-Site Scripting (XSS) in TPVENlanube affecting the following endpoint and parameter: * CVE-2026-7170: parameter 'vendor_store_name' in the endpoint '/administrator/index.php?pshop_mode=admin&page=store.store_add&option=com_virtuemart&vendor_id=[ID]'. Successful exploitation of this vulnerability could allow an authenticated attacker to inject malicious c...
CVE-2026-7171	New	4.8	MEDI				Stored Cross-Site Scripting (XSS) in TPVENlanube affecting the following endpoint and parameter: * CVE-2026-7171: parameter 'Apellido 1' in the endpoint '/administrator/index.php?page=admin.user_add&user_id=45&option=com_virtuemart'. Successful exploitation of this vulnerability could allow an authenticated attacker to inject malicious code and execute it in users' br...
CVE-2026-7172	New	4.8	MEDI				Stored Cross-Site Scripting (XSS) in TPVENlanube affecting the following endpoint and parameter: * CVE-2026-7172: parameter 'Nombre Completo' in the endpoint '/administrator/index.php?option=com_virtuemart&page=admin.user_list'. Successful exploitation of this vulnerability could allow an authenticated attacker to inject malicious code and execute it in users' brows...
CVE-2026-100370	New	4.7	MEDI				DOMSanitizer is a DOM/SVG/MathML Sanitizer for PHP 7.3+. Prior to version 1.0.15, the isDangerousUrl() method is responsible for rejecting dangerous URL values in the href and xlink:href attributes. The weakness is that "javascript:" is rejected as a scheme, while "data:" is rejected only when the literal substring onload appears in the URL value (/^data:.*onload/i). Because...
CVE-2026-101018	New	4.7	MEDI				A vulnerability was determined in dayrui XunruiCMS up to 4.7.2. This issue affects the function group_all_edit of the file dayrui/App/Member/Controllers/Admin/Home.php of the component Group Editing. This manipulation of the argument groupid causes sql injection. The attack is possible to be carried out remotely. The exploit has been publicly disclosed and may be utilized. T...
CVE-2026-101858	New	4.7	MEDI				A flaw has been found in RaspAP raspap-webgui up to 3.5.5. Affected is the function WiFiManager::writeWpaSupplicant of the file src/RaspAP/Networking/Hotspot/WiFiManager.php of the component SSID Processing. This manipulation of the argument ssid causes os command injection. The attack can be initiated remotely. The exploit has been published and may be used. The vendor was ...
CVE-2026-102263	New	4.7	MEDI				A vulnerability has been found in mwasikz robo-cafe-rms up to 228c44a02823f04e85db32b7137809a2856148fc. The affected element is an unknown function of the file manage-food.php. Such manipulation leads to unrestricted upload. The attack may be launched remotely. The exploit has been disclosed to the public and may be used. This product operates on a rolling release basis, ens...
CVE-2026-59563	New	4.6	MEDI				Zscaler MCP Server versions 0.7.0 and 0.7.1 has an issue where HMAC confirmation tokens were not bound to the target resource identifier, allowing an MCP client or agent to replay a token generated for one resource to affect another resource of the same type. This issue is fixed in version 0.7.2.
CVE-2026-102270	New	4.4	MEDI				PyJWT is a Python implementation of JSON Web Token standards. Prior to 2.14.0, PyJWT is _pem_format is affected because lazy PEM regular expression backtracks extensively. This occurs when a certificate-like input contains repeated BEGIN markers without a matching END marker. As a result, is_pem_format performs unbounded backtracking while searching for a PEM end marker. Cons...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102366	New	4.4	MEDI				mall4j through 4.0 contains an unrestricted file upload vulnerability in FileController endpoints that lack authorization checks and accept arbitrary file types without validation. Attackers with any authenticated token can upload HTML or SVG files that execute scripts in administrator browsers when accessed from the local storage path, resulting in stored cross-site scripting.
CVE-2026-101006	New	4.3	MEDI				A flaw has been found in Frappe HR up to 16.15.0. This vulnerability affects the function get_expense_claims/get_shift_requests/get_attendance_requests of the file hrms/api/__init__.py of the component Permission Validation. This manipulation of the argument employee causes incorrect authorization. Remote exploitation of the attack is possible. The vendor replied: "This issu...
CVE-2026-101099	New	4.3	MEDI				A vulnerability was detected in ag-ui-protocol ag-ui up to 2026-09-23. This affects an unknown part of the file SseParser.kt of the component Kotlin Community SDK. Performing a manipulation results in handling of exceptional conditions. The attack may be initiated remotely. The pull request to fix this issue awaits acceptance.
CVE-2026-101143	New	4.3	MEDI				A vulnerability was found in Eleveo Quality Management 9.7.0. Affected by this issue is some unknown functionality of the file /qm/cz.zoom.scorecard.webui.Scorecard/cz.zoom.scorecard.webui.Scorecard/QMBODownload. The manipulation results in information disclosure. The attack may be launched remotely. The exploit has been made public and could be used. The vendor was contacte...
CVE-2026-101145	New	4.3	MEDI				A vulnerability was identified in Eleveo Call Recording Software 9.7.0. This vulnerability affects unknown code of the file /callrec/userAddAction.do of the component User Management. Such manipulation of the argument Username leads to ldap injection. The attack can be executed remotely. The exploit is publicly available and might be used. The vendor was contacted early abou...
CVE-2026-101146	New	4.3	MEDI				A security flaw has been discovered in Eleveo Quality Management 9.7.0. This issue affects the function UtilsService.createAndSaveAudit of the file /qm/cz.zoom.scorecard.webui.Scorecard/QMUtilsService of the component GWT RPC Handler. Performing a manipulation results in information disclosure. The attack is possible to be carried out remotely. The exploit has been released ...
CVE-2026-101278	New	4.3	MEDI				A weakness has been identified in Trusted Domain Project OpenDMARC up to 1.4.2. This affects the function opendmarc_get_tld of the file libopendmarc/opendmarc_tld.c : of the component PSL Wildcard Handler. Executing a manipulation can lead to origin validation error. The attack may be launched remotely. The exploit has been made available to the public and could be used for ...
CVE-2026-102244	New	4.3	MEDI				A security flaw has been discovered in MODSetter SurfSense up to 0.0.36. Impacted is an unknown function of the file surfsense_backend/app/routes/editor_routes.py of the component Document Export Feature. Performing a manipulation results in server-side request forgery. The attack can be initiated remotely. The exploit has been released to the public and may be used for atta...
CVE-2026-102297	New	4.3	MEDI				ZoneMinder before 1.38.4 fails to apply per-monitor access restrictions in the FramesController index endpoint. Authenticated users with Events view permission can call the frames API to list frame records from monitors they are denied access to, disclosing event and frame metadata across monitor boundaries.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-13018	New	4.3	MEDI				Insufficient validation of untrusted input in Codecs in Google Chrome prior to 147.0.7727.55 allowed a remote attacker to potentially perform out of bounds memory access via a crafted video file. (Chromium security severity: Low)
CVE-2026-86334	New	4.2	MEDI				Path traversal in the CLI client image export and copy functionality in Canonical LXD from 4.0.2 before 4.0.14, 5.0.10, 5.21.8, and 6.10 on all platforms allows a remote malicious or machine-in-the-middle image server to overwrite arbitrary local files and execute code on the client system via a crafted Content-Disposition header filename parameter during unified image expor...
CVE-2026-101861	New	4.1	MEDI				Langflow 1.0.16 before 1.12.0 and 0.0.94 before 1.12.0 contain an unsafe eval() vulnerability in schema.py that allows authenticated attackers to achieve code execution by placing a Python object with a malicious __repr__ method into component input options lists. The eval() sink is triggered when a component is converted into a LangChain tool via ComponentToolkit.get_tools(...
CVE-2026-82326	New	4.1	MEDI				Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in Enocta Educational Technologies Inc. Enocta Platform allows XSS Targeting HTML Attributes. This issue affects Enocta Platform: through 2026-09-28.
CVE-2026-97026	New	3.9	LOW				Flatpak creates temporary child repository directories under the user cache with world-writable permissions (0777). On multi-user systems with a permissive umask, other local users could read or modify the temporary directory used while installing apps or runtimes, potentially causing installation failures (denial of service); tampered content would fail signature/digest ver...
CVE-2026-101333	New	3.7	LOW				A flaw was found in the Micrometer user-event metrics listener of Keycloak, a solution for integrated identity and access management. The issue occurs when the listener is configured to include the idp tag. An unauthenticated attacker can send requests to the identity broker login endpoint using arbitrary provider aliases, causing the system to create an unlimited number of ...
CVE-2026-101915	New	3.7	LOW				@grpc/grpc-js implements the core functionality of gRPC purely in JavaScript, without a C++ addon. Prior to 1.13.6 and 1.14.5, when an application method handler throws an uncaught error, the server includes its error message in the status message sent to the client. The thrown error message is transmitted to the client, causing sensitive information disclosure when the mess...
CVE-2026-102363	New	3.7	LOW				mall4j through 4.0 contains a missing authentication vulnerability in the DeliveryController checkDelivery endpoint that allows unauthenticated attackers to read shipment tracking information by supplying an order number parameter. Attackers can access carrier names, waybill numbers, and complete logistics trails for any order without authentication or ownership verification.
CVE-2026-18416	New	3.7	LOW				The CoAP link-format helper match_path_uri() in subsys/net/lib/coap/coap_link_format.c compares a registered resource path against the URI carried in a Uri-Query href= option. That URI is not NUL terminated, but the inner character loop advanced its index k once per path character without ever testing it against the option length len. When a registered path segment is longer...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97399	New	3.7	LOW				The strncasecmp function in the GNU C Library 2.24 and later optimized for the Power8 architecture may read one byte beyond the input size limit, which may crash a program when that byte is not readable. This condition may happen when the input strings to the strncasecmp function are attacker controlled in an application and they match all the way up to the edge of their pa...
CVE-2026-97027	New	3.6	LOW				Flatpak passes through arbitrary vendor-extension keys unmodified when exporting an application's Desktop Entry (.desktop) and D-Bus Service (.service) files, instead of validating against an allowlist. A malicious Flatpak app can use this to cause denial of service (e.g. forced application restart loops) or to influence host D-Bus/systemd activation behavior beyond what the...
CVE-2026-101141	New	3.5	LOW				A flaw has been found in Eleveo Call Recording Software 9.7.0. Affected is an unknown function of the file /callrec/audio.jsp of the component Play Audio Page. Executing a manipulation of the argument viewRoleId/cfType can lead to cross site scripting. The attack can be launched remotely. The exploit has been published and may be used. The vendor was contacted early about th...
CVE-2026-102264	New	3.5	LOW				A vulnerability was found in mwasikz robo-cafe-rms up to 228c44a02823f04e85db32b7137809a2856148fc. The impacted element is an unknown function of the file frontend/update-account.php of the component Edit Profile Feature. Performing a manipulation of the argument Name/Address/City results in cross site scripting. Remote exploitation of the attack is possible. The exploit has...
CVE-2026-102290	New	3.5	LOW				A vulnerability was determined in CodeCanyon Rocket LMS up to 2.2. This affects an unknown function of the component Student Profile Image Upload. Executing a manipulation can lead to cross site scripting. The attack can be executed remotely. The exploit has been publicly disclosed and may be utilized. The vendor was contacted early about this disclosure but did not respond ...
CVE-2026-101131	New	3.3	LOW				A vulnerability was identified in deepseek-ai deepseek-harness up to 0.1.5-rc.3. Impacted is an unknown function of the file packages/e2b/e2b/src/index.ts of the component dsh. The manipulation of the argument E2B_API_KEY leads to reliance on untrusted inputs in a security decision. Local access is required to approach this attack. The exploit is publicly available and might...
CVE-2026-97025	New	3.2	LOW				Flatpak writes the OCI repository authentication token with world-readable permissions (0644) in the system-helper's cache directory, allowing other local users on a multi-user system to read the token and impersonate the authenticated user against the OCI repository. Only OCI-based sources (e.g. as used by Fedora) are affected; libostree-based sources such as Flathub are not.
CVE-2026-101132	New	3.1	LOW				A security flaw has been discovered in DeepSeek deepseek-harness up to 0.1.7-rc.2. The affected element is the function loadProfile of the file packages/boot/app-boot/src/profile.ts of the component Bundle Patch Handler. The manipulation of the argument dsh.bundle.patch results in path traversal. The attack may be performed from remote. The attack requires a high level of co...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101265	New	3.1	LOW				A vulnerability was identified in Intelbras TIP 125i 4.3.35/4.3.41. The affected element is an unknown function of the component Básico Page. Such manipulation leads to inclusion of sensitive information in source code. The attack can be launched remotely. A high complexity level is associated with this attack. The exploitability is described as difficult. The exploit is pub...
CVE-2026-102279	New	3.1	LOW				Laravel is a web application framework. Prior to 12.69.0 and 13.30.0, Laravel exception debug pages with APP_DEBUG=true pass attacker-controlled input to a Tippy.js tooltip configured with allowHTML true, enabling DOM-based cross-site scripting when a user hovers over the tooltip. This issue is fixed in versions 12.69.0 and 13.30.0.
CVE-2026-101079	New	2.8	LOW				A vulnerability was found in agentverus agentverus-scanner up to 0.8.1. Affected by this vulnerability is the function isSecurityDefenseSkill of the file dist/scanner/analyzers/context.js. Performing a manipulation results in reliance on untrusted inputs in a security decision. The attack must be initiated from a local position. The exploit has been made public and could be ...
CVE-2026-102241	New	2.7	LOW				A vulnerability was determined in Netcore NAP930 0.1.241010.141410. This vulnerability affects unknown code of the file /lib/functions/backup_common.sh of the component Backup/Restore. This manipulation of the argument aes_pass causes use of hard-coded cryptographic key . It is possible to initiate the attack remotely. The exploit has been publicly disclosed and may be util...
CVE-2026-101071	New	2.1	LOW				A vulnerability was determined in Acrel Electric Unet Web Service up to 20260814. This vulnerability affects unknown code of the file /exchange/attachment/upload of the component Upload Endpoint. This manipulation of the argument File causes unrestricted upload. The attack can be initiated remotely. The exploit has been publicly disclosed and may be utilized. The vendor was ...
CVE-2026-101010	New	2.0	LOW				A vulnerability was identified in aaPanel BaoTa up to 11.8.0. The impacted element is the function getData of the file /www/server/panel/class/data.py. The manipulation of the argument log_type leads to sql injection. It is possible to initiate the attack remotely. The exploit is publicly available and might be used. The vendor was contacted early about this disclosure but d...
CVE-2026-101011	New	2.0	LOW				A security flaw has been discovered in aaPanel BaoTa up to 11.8.0. This affects the function get_domain_status of the file /www/server/panel/mod/project/domain/domainMod.py of the component Domain Handler. The manipulation of the argument get results in sql injection. It is possible to launch the attack remotely. The exploit has been released to the public and may be used fo...
CVE-2026-101139	New	2.0	LOW				A vulnerability was detected in Webkul Bagisto up to 2.4.6. This impacts an unknown function of the file /admin/sales/invoices/mass-update/state of the component Invoice Mass Status Update. Performing a manipulation results in missing authorization. The attack can be initiated remotely. The exploit is now public and may be used. The vendor was contacted early about this disc...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101036	New	1.9	LOW				A vulnerability has been found in FLB-Music FLB-Music-Player 1.1.8/1.1.9/1.2.0/1.2.1. This impacts the function path.join of the file /src/main/core/createParsedTrack.ts. The manipulation leads to path traversal. The attack must be carried out locally. The exploit has been disclosed to the public and may be used. The vendor was contacted early about this disclosure but did n...
CVE-2026-101078	New	1.9	LOW				A vulnerability has been found in deepseek-ai deepseek-harness up to 0.1.7-rc.2. Affected is an unknown function of the file packages/sandbox/sandbox-local/src/profiles.ts of the component Landlock Backend. Such manipulation leads to improper isolation or compartmentalization. The attack must be carried out locally. The exploit has been disclosed to the public and may be use...
CVE-2026-101080	New	0.9	LOW				A vulnerability was identified in Tencent AI-Infra-Guard up to 4.5.2/4.6.2. This affects the function startsWith of the file skill_scan/tools/dir/dir_actions.py of the component File Access. The manipulation leads to path traversal. The attack needs to be performed locally. The exploit is publicly available and might be used. Upgrading to version 4.6.0 is able to mitigate th...
CVE-2026-100701	New		MODE			npm:nodemailer	### Summary Nodemailer's process-global DNS cache is keyed only by `host`, but each cache entry also stores the caller-specific TLS `servername`. When two direct SMTPS transports use the same DNS host with different `tls.servername` values, the first transport's server name is returned to the second transport and overwrites its explicitly configured value. As a result, Nod...
CVE-2026-101062	New					Go:github.com/obot-platform/obot	Obot: OAuth Dynamic Client Registration Enables API Token Theft via Audience Confusion in github.com/obot-platform/obot
CVE-2026-101895	New		HIGH			npm:@angular/platform-server	A Denial of Service (DoS) vulnerability exists in `@angular/platform-server`'s DOM emulation parser (`domino`). When processing untrusted user input containing an incomplete DOCTYPE declaration ending with whitespace before EOF (such as `<!DOCTYPE html `), the HTML parser enters an infinite synchronous loop, pegging CPU utilization at 100% and completely freezing the Node.js...
CVE-2026-10601	New					Go:github.com/grafana/grafana	Grafana: Path traversal in the Tempo and Loki data source plugins in github.com/grafana/grafana. NOTE: The source advisory for this report contains additional versions that could not be automatically mapped to standard Go module versions. (If this is causing false-positive reports from vulnerability scanners, please suggest an edit to the report.) The additional affected ...
CVE-2026-12249	New					Go:github.com/ubuntu/adsys	Canonical ADSys Uses a Less Trusted Source in github.com/ubuntu/adsys. NOTE: The source advisory for this report contains additional versions that could not be automatically mapped to standard Go module versions. (If this is causing false-positive reports from vulnerability scanners, please suggest an edit to the report.) The additional affected modules and versions are: ...
CVE-2026-19032	New		MODE			Maven:com.fasterxml.jackson.core:jackson-databind, Maven:tools.jackson.core:jackson-databind	### Summary A `java.nio.file.Path` field bound from untrusted JSON reaches `JDKFromStringDeserializer.NioPathHelper.deserialize`. The attacker string flows through `new URI(value)` → `Path.of(uri)`, then on `FileSystemNotFoundException` into a `ServiceLoader<FileSystemProvider>` enumeration that calls `provider.getPath(uri)` on the first scheme-matching provider. No scheme ...
CVE-2026-32599	New					Go:github.com/gravitl/netmaker	Netmaker has a boolean-based SQL Injection in github.com/gravitl/netmaker

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-42127	New					Go:github.com/grafana/grafana	Grafana: Pre-authentication denial of service in the public dashboard query handler in github.com/grafana/grafana. NOTE: The source advisory for this report contains additional versions that could not be automatically mapped to standard Go module versions. (If this is causing false-positive reports from vulnerability scanners, please suggest an edit to the report.) The ad...
CVE-2026-42129	New					Go:github.com/grafana/grafana	Grafana Loki datasource plugin's callResource handler contains a path traversal vulnerability. in github.com/grafana/grafana. NOTE: The source advisory for this report contains additional versions that could not be automatically mapped to standard Go module versions. (If this is causing false-positive reports from vulnerability scanners, please suggest an edit to the repor...
CVE-2026-5139	New					Go:github.com/mattermost/mattermost-server	Mattermost doesn't enforce administrator authorization on the {{setDefaultInstance}} call within the {{gitlab connect}} command handler in github.com/mattermost/mattermost-server
CVE-2026-58197	New					Go:github.com/stacklok/toolhive	ToolHive: containerized MCP servers can reach host services via host.docker.internal, enabling lateral movement in github.com/stacklok/toolhive
CVE-2026-58463	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-58464	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-6062	New					Go:github.com/mattermost/mattermost-server	Mattermost doesn't validate channel ownership of an existing subscription before applying edits in github.com/mattermost/mattermost-server
CVE-2026-61554	New					Go:github.com/jm33-m0/emp3r0r/core	emp3r0r has an unauthenticated HTTP Polling DoS in github.com/jm33-m0/emp3r0r/core
CVE-2026-61628	New					Go:github.com/lucasdillmann/nginx-ignition	nginx ignition has Unauthenticated Admin Account Creation via Onboarding Race Condition in github.com/lucasdillmann/nginx-ignition. NOTE: The source advisory for this report contains additional versions that could not be automatically mapped to standard Go module versions. (If this is causing false-positive reports from vulnerability scanners, please suggest an edit to the...
CVE-2026-61629	New					Go:github.com/lucasdillmann/nginx-ignition	nginx ignition has ParseAcceptLanguage ` _ ` separator bypass that enables ~75x CPU amplification via Accept-Language header in i18nMiddleware in github.com/lucasdillmann/nginx-ignition
CVE-2026-61630	New					Go:github.com/lucasdillmann/nginx-ignition	nginx ignition has TOTP Reuse During Validity Window in github.com/lucasdillmann/nginx-ignition
CVE-2026-61672	New					Go:github.com/projectcapsule/capsule	Capsule: Tenant owner bypasses Capsule's forbidden namespace/service/node label and annotation enforcement in github.com/projectcapsule/capsule
CVE-2026-61682	New					Go:github.com/kcp-dev/kcp	kcp front-proxy does not strip inbound X-Remote-* identity headers, allowing any authenticated client to inject groups/warrants and impersonate system:masters in any workspace in github.com/kcp-dev/kcp

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-61687	New					Go:github.com/hatchet-dev/hatchet	Hatchet - Unauthenticated OAuth state CSRF / login-CSRF via empty-state collision in ValidateOAuthState in hatchet in github.com/hatchet-dev/hatchet. NOTE: The source advisory for this report contains additional versions that could not be automatically mapped to standard Go module versions. (If this is causing false-positive reports from vulnerability scanners, please sugg...
CVE-2026-61709	New					Go:github.com/openfga/openfga	OpenFGA: ListUsers returns a deliberately-excluded user when a `but not` exclusion under a type-bound wildcard is intersected (`and`) with another relation that also grants that user in github.com/openfga/openfga
CVE-2026-61794	New					Go:github.com/projectcapsule/capsule	Capsule: Malformed ForbiddenAnnotations.Regex can bypass Tenant validation and trigger namespace admission panic in github.com/projectcapsule/capsule
CVE-2026-61795	New					Go:github.com/projectcapsule/capsule	Capsule: hostnameRegexHandler.OnUpdate validates stale (old) Tenant regex, allowing invalid AllowedHostnames regex to bypass webhook validation in github.com/projectcapsule/capsule
CVE-2026-61833	New					Go:zotregistry.dev/zot, Go:zotregistry.dev/zot/v2	zot: Bearer authentication maps DELETE to push scope, allowing unauthorized deletion in zotregistry.dev/zot
CVE-2026-61834	New		MODE			npm:scim-patch	## Summary Incomplete Prototype Pollution Fix Allows Mutation of Inherited Built-in Method Objects `scim-patch` blocks direct dangerous path segments such as `__proto__`, `constructor`, and `prototype`, but still traverses inherited properties when applying SCIM patch paths. An attacker who controls a SCIM PATCH operation can use paths such as `toString.polluted` to mutat...
CVE-2026-63199	New					Go:github.com/perses/perses	Perses's missing authorization in datasource proxy allows cross-scope secret disclosure in github.com/perses/perses
CVE-2026-63405	New					Go:github.com/anycable/anycable-go	AnyCable: Pusher REST API Does Not Verify Request Body MD5 Enabling Signed-Request Replay with Arbitrary Body in github.com/anycable/anycable-go. NOTE: The source advisory for this report contains additional versions that could not be automatically mapped to standard Go module versions. (If this is causing false-positive reports from vulnerability scanners, please suggest ...
CVE-2026-63406	New					Go:github.com/anycable/anycable-go	AnyCable: Telemetry Subsystem Contains Hardcoded Authentication Token and Transmits CLI Arguments Including Secrets in github.com/anycable/anycable-go. NOTE: The source advisory for this report contains additional versions that could not be automatically mapped to standard Go module versions. (If this is causing false-positive reports from vulnerability scanners, please su...
CVE-2026-63445	New					Go:github.com/perses/perses	Perses's unvalidated project parameter enables filesystem path traversal in github.com/perses/perses
CVE-2026-63458	New					Go:github.com/perses/perses	Perses's project query parameter authorization bypass exposes cross-project resources in github.com/perses/perses
CVE-2026-6673	New					Go:github.com/mattermost/mattermost-server	Mattermost doesn't authenticate Atlassian Connect installed callbacks, allowing a remote unauthenticated attacker to inject a rogue sharedSecret in github.com/mattermost/mattermost-server

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-68497	New		HIGH			Maven:com.fasterxml.jackson.core:jackson-databind, Maven:tools.jackson.core:jackson-databind	### Summary `jackson-databind` 3.2.1 deserializes a JSON string bound to a `javax.xml.datatype.Duration` or `javax.xml.datatype.XMLGregorianCalendar` field by passing the raw string verbatim to `DatatypeFactory.newDuration(value)` / `newXMLGregorianCalendar(value)`. Per the XML-Schema lexical grammar these factory methods accept numeric components of arbitrary length, wh...
CVE-2026-71485	New					Go:github.com/centrifugal/centrifugo, Go:github.com/centrifugal/centrifugo/v3, Go:github.com/centrifugal/centrifugo/v4,	Centrifugo: Client-forgeable headers emulation lets any client spoof headers forwarded to proxy backends in github.com/centrifugal/centrifugo
CVE-2026-77310	New		MODE			Maven:com.fasterxml.jackson.core:jackson-databind, Maven:tools.jackson.core:jackson-databind	### Summary CVE-2026-54514 (GHSA-hgj6-7826-r7m5) fixed an eager-DNS-resolution / SSRF issue in jackson-databind's deserialization of `java.net.InetSocketAddress` by switching to `InetSocketAddress.createUnresolved(...)` (PR #5951, commit 1f5a1037, released in 2.18.8 / 2.21.4 / 3.1.4). That fix did not cover the sibling `java.net.InetAddress` branch in the very same `FromStr...
CVE-2026-77339	New					Go:github.com/f1bonacc1/process-compose	Process Compose: Browser DNS rebinding lets websites control local process-compose MCP tools in github.com/f1bonacc1/process-compose
CVE-2026-8074	New					Go:github.com/mattermost/mattermost-server	Mattermost doesn't enforce bot-specific permission checks on the user active status endpoint in github.com/mattermost/mattermost-server
CVE-2026-81505	New					Go:github.com/frain-dev/convoy	Convoy: Cross-Tenant Source IDOR Leaks Plaintext Message Broker Credentials in github.com/frain-dev/convoy
CVE-2026-81871	New					Go:go.opentelemetry.io/otel/exporters/otlp/otlplog/otlploggrpc	OpenTelemetry-Go: Log gRPC exporter ignores env TLS certs, bypassing mTLS/pinning in go.opentelemetry.io/otel/exporters/otlp/otlplog/otlploggrpc
CVE-2026-82399	New					Go:github.com/coredns/coredns	CoreDNS: Unauthenticated memory exhaustion in custom transports in github.com/coredns/coredns
CVE-2026-83557	New		MODE			Maven:com.fasterxml.jackson.core:jackson-databind, Maven:tools.jackson.core:jackson-databind	### Summary `DefaultBaseTypeLimitingValidator` — the `PolymorphicTypeValidator` used automatically whenever `@JsonTypeInfo` is applied without an explicitly configured custom validator — denies polymorphic resolution only for nine specific "unsafe base types" (`Object`, `Serializable`, `Closeable`, `AutoCloseable`, `Cloneable`, `Runnable`, `java.util.logging.Handler`, `javax...
CVE-2026-84292	New		HIGH			npm:fast-uri	### Impact `fast-uri` serializes the `port` component of a URI without validating it. When recomposing the authority, `fast-uri` escapes the userinfo and host components but concatenates the port verbatim, so a `port` value that is not a sequence of digits can inject authority delimiters. For example, serializing a component whose `port` is `@127.0.0.1:8124` produces `http...
CVE-2026-84394	New		HIGH			npm:fast-uri	### Impact `fast-uri` accepts a host that contains an unbalanced or misplaced authority bracket (`[` or `]`) without reporting an error. A host that starts with `[` but does not end with `]`, such as `[@127.0.0.1`, is neither validated as an IP literal nor canonicalized as a domain name, so `parse()` returns it as the host with `error` undefined, while Node's `URL` (and `ht...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84894	New						In moxygen before commit 004123dd24c3, MoQSession::dataStreamReadLoop keeps using a stream read handle after reading a FIN, which invalidates the handle under proxygen's WebTransport API. A remote peer can trigger the stale use by opening a data stream that names an unknown track alias and carries the FIN in the same write.
CVE-2026-84895	New						In proxygen from v2026.04.06.00 until v2026.09.28.00, QuicWtSession::closeSession accesses its member fields after calling the base QuicWtSessionBase::closeSession method. The base method notifies the session handler, which may release the last reference to the session and destroy it.
CVE-2026-85024	New		MODE			npm:undici	## Impact undici's WebSocket client (including Node.js's bundled `globalThis.WebSocket`) crashes the entire Node.js process when a remote WebSocket peer sends a permessage-deflate compressed message that crosses the decompressed-payload size limit and then contains a malformed DEFLATE block. In `lib/web/websocket/permessage-deflate.js`, the size-limit cleanup calls `removeA...
CVE-2026-85644	New						XS::Parse::Infix versions from 0.40 through 0.49 for Perl treat a number as an array reference. The wrapper function XS::Parse::Infix generates for a list-associative infix operator checks whether arguments are array references, but it tests using SvRV() rather than SvROK(). SvRV() reads a union slot that only holds a referent once SvROK(sv) is true, so the guard never vali...
CVE-2026-86003	New					Go:github.com/coredns/coredns	CoreDNS DoH/DoQ/gRPC bypass UPDATE rejection enforced on UDP/TCP in github.com/coredns/coredns
CVE-2026-86043	New					Go:github.com/zalando/skipper	Skipper has OPA body-authz bypass: truncated_body mitigation fails open on chunked/HTTP-2 (incomplete fix GHSA-8qqm-fp2q-v734) in github.com/zalando/skipper
CVE-2026-87859	New		MODE			npm:morgan	### Impact Morgan writes attacker-controlled request data to the access log. Its escaping (added in 1.11.0 and 1.12.0) neutralizes control characters, the Unicode line separators, and backslash, but not the double quote (`0x22`), which is the field delimiter of the Apache combined log format morgan emits. An attacker who controls a quoted field (:user-agent`, :referrer`, ...
CVE-2026-88058	New		HIGH			npm:@angular/platform-server	### Summary An XSS vulnerability exists in `@angular/platform-server` during server-side rendering (SSR) HTML serialization of `ProcessingInstruction` DOM nodes (`<?target data?>`, `nodeType === 7`) when nested inside fallback raw-content elements (`<noscript>`, `<iframe>`, `<noembed>`, `<noframes>`). While processing instruction data escaped `>` to `>`, it did not check ...
CVE-2026-88815	New						DBI versions before 1.654 for Perl incorrectly treat numeric values as strings in sql_type_cast_svpv. When casting to SQL_NUMERIC, sql_type_cast_svpv passes the string pointer and length of the SV to grok_number without stringifying it first. An integer (IV) or floating-point (NV) value has no valid string pointer, so grok_number reads from an invalid address, triggering a ...
CVE-2026-88816	New						DBI versions before 1.654 for Perl incorrectly treat numeric values as strings in FetchHashKeyName. fetchrow_hashref uses the string pointer of the FetchHashKeyName attribute as the key name without stringifying it first. When FetchHashKeyName has been set to an integer (IV) or floating-point (NV) value, that pointer is invalid, so reading the key name triggers a segmentati...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88932	New		MODE			npm:multer	### Impact Multer's `diskStorage` can leave complete, orphaned files on disk when a multipart upload is aborted in the brief window before the storage engine assigns the file path. This is an incomplete fix of CVE-2026-5038: the earlier cleanup removes only in-flight uploads that already have a path, so an upload aborted inside that window is written to disk with nothing le...
CVE-2026-9029	New					Go:github.com/grafana/grafana	Grafana geomap panel's XYZ tile layer has a sanitize-then-interpolate ordering bug in github.com/grafana/grafana. NOTE: The source advisory for this report contains additional versions that could not be automatically mapped to standard Go module versions. (If this is causing false-positive reports from vulnerability scanners, please suggest an edit to the report.) The add...
CVE-2026-90979	New						LDAPCache and LDAPBackingEngine build LDAP search filters for user lookup and role lookup by textually substituting the placeholders %u, %dn, and %fqdn (drawn from the login name, the resolved user DN, and its fully qualified namespace form) into administrator-configured filter templates (userFilter, roleFilter). Before the fix, the only sanitization applied to the substitut...
CVE-2026-91006	New						Apache Karaf's instance-management service (InstanceServiceImpl) builds the command line used to launch a child Karaf JVM by string concatenation, then executes it through /bin/sh (Unix) or cscript (Windows). The caller-supplied javaOpts value is spliced into that string unquoted. A javaOpts value containing shell metacharacters (;, , `, \$(...)) is interpreted by the shell ...
CVE-2026-91095	New						In proxygen from v2024.10.28.00 until v2026.09.28.00, the HTTPTransaction::onWebTransportUniStream and HTTPTransaction::onWebTransportBidiStream APIs could return stream handles that the stream handler had already freed. HQSession then installed those handles as transport read callbacks, which could lead to use of freed memory.
CVE-2026-91096	New						In proxygen from v2024.10.28.00 until v2026.09.28.00, WebTransportImpl::terminateSessionStreams (WebTransportImpl::destroy in releases before v2025.08.18.00) failed to unregister read callbacks for streams that were no longer open before destroying them. The transport could then invoke a read callback that had been freed.
CVE-2026-9162	New					Go:github.com/mattermost/mattermost-server	Mattermost doesn't invalidate cached authentication state for active WebSocket connections during global session revocation in github.com/mattermost/mattermost-server
CVE-2026-96760	New						Authlib (v1.7.2 and below) contains a signature verification bypass vulnerability. The JsonWebSignature.deserialize_json() method accepts a JSON Serialization JWS object and returns the payload as successfully verified without checking for a signature and without requiring a cryptographic key.
GHSA-2gr6-gxvx-3594	New					npm:nebulajs-api	--- _== Per source details. Do not edit below this line.--_ ## Source: amazon-inspector (07debd960454b52639fee783e21c0c303702d8dce6de5e3320393f1b0abc7077) package.json declares scripts.preinstall = 'node preinstall.cjs'. preinstall.cjs is a single ~232KB opaque Function(...) invocation containing a custom PRNG-based string decoder (VnDKxn using constants 0x9e3779b9, 0x243f...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-456v-xq2p-r4cj	New		HIGH			npm:code-ollama	## `grep_search` Command Injection via Unescaped `\$()` Shell Substitution (CWE-78) ### Summary The `grep_search` tool in `code-ollama` constructs a shell command string by interpolating attacker-controlled `pattern` and `path` arguments, then executes it via `child_process.exec()`. The sanitization only escapes backslashes and double-quote characters, leaving `\$()` command...
GHSA-65gf-jmp3-4wrc	New					npm:wbnr-probe-visible-check	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (a1f50ae8c3560fd6aedcceecf9e5289ed72c06bd746e21c4925b402c5d1ef3f9) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-865f-pwj5-p2c5	New					npm:@wbnr/design-kit	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (c3b05ae1cf2f1c184b793a46f4bebd59f7945ef1f671c4e6bd64ee946c416e2b) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-94r6-cxjq-fq4r	New					npm:@wbnr/lottiefiles-loader	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (2f4124e4c91354a00657c25874fb6b9f762438eee2ecd1d8b686af3d4d4ea8c9) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-9f7c-6fp7-9g6x	New					npm:kjj81	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (73eb4923beefd1002ed194dadf8c7712ed082fbd0d9dcdcfba1db3a02e1fa82ef) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-cxrh-669r-w2g9	New					npm:tailwindcss-form-kit	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (db00b593e7fc0c9c362e06fce588b1fa25a695114032504a7d6c72f5141f39ae) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-fm5g-6rr8-p9vq	New					npm:nebula-sdk	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (f0ca45fda7abd51edfeef37be6d19b4070788180b7625f16354223d81dae4d45) The preinstall.cjs lifecycle script embeds a base64-encoded, zlib-compressed Windows PE (~257KB) as a string literal. On `npm install`, the script decodes and decompresses the blob, writes the resulting executable to %LO...
GHSA-jhjp-4c2q-xmx4	New					Go:github.com/falcosecurity/plugins/plugins/k8saudit, Go:github.com/falcosecurity/plugins/plugins/k8saudit-aks, Go:github	k8saudit shipped rules do not detect privileged/sensitive settings on init or ephemeral containers in github.com/falcosecurity/plugins/plugins/k8saudit
GHSA-jxw5-69p3-hpm4	New					npm:native-runner	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (c057973da17ec629b4cd8c10a2b74108761f4a9ad4a1a31b280031da1f7139ca) On `require('native-runner')`, a top-level IIFE in index.js polls for up to two minutes for a file at %APPDATA%\Microsoft\Windows\node_runtime_helper.exe and, once present, spawns it via child_process.spawn with {detache...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-mh9w-qr45-6wrq	New					npm:vite-plugin-crypto	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (54ee82c069dcdf259199f5844c6ff46be3020d79609ff7b7b8ebc82017c59b2c) vite-plugin-crypto@1.0.2 exposes a Vite plugin factory whose body concatenates three option fields — `secret`, `salt`, and `iv` — into a single string and passes it to `System.import(...)` from the `systemjs` runtime mod...
GHSA-pm4h-xrhq-vh62	New					npm:kalasnik-npm-simple-test	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (f1463688412306d5d6f791bb036bea59aeb7251a3044a52c57119768f27cd463) The package's postinstall script send_data.js runs automatically on npm install. It reads C:\temp\test.txt from the installer's filesystem and POSTs the contents over plain HTTP to a hardcoded remote endpoint at 35.178.1...
GHSA-pqvc-prrc-mv45	New					npm:uuid-date	--- _-= Per source details. Do not edit below this line.=_ ## Source: ghsa-malware (1794c1dba5ffb902f0c8011a60990baff7cf5ebc1f90ab634937734944696995) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-pv7p-ghgv-268x	New					npm:img-to-native	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (7676788d88c2194b8d5c048decfb06550798ce342af54f8975bc26422d10c53) On require() of img-to-native, index.js reads banner.jpg from the.cache directory of its sole dependency cdn-img-fetch, locates a payload appended after the PNG IEND marker, base64-decodes it, and AES-256-CBC decrypts it...
GHSA-w4g6-rgx4-2wjf	New					npm:my-skibidi	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (02c4b3433d9f819c70b6ec69fe7bccc0ae0a7ff48540e11394ea5fb8f3c49049c) my-skibidi@1.0.2 contains top-level code in its main module that unconditionally POSTs `document.cookie` to the hardcoded remote endpoint https://c-b34596407b6d47d6.dgactf-challs.site/addPost via a `sendPost(...)` call. ...
MAL-2026-17213	New					PyPI:azure-langchain-example	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (1cffc3a51858b1b7a17ff0edfd2eeae6383e83b4eff5bc078f7b1d4f5ba36ad2) On `import azure_langchain_example`, the package's __init__.py starts a background daemon thread that issues a GET request to https://litellm.adversarylabx.com/telemetry with the installer's hostname, resolved IP address...
MAL-2026-17214	New					npm:git-en-boite-logging	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (f6ebee9f4428d7f14f6f941438064715c8bece34c5fe6bfedf32bbd8cba226c0) package.json declares a preinstall lifecycle hook that runs `wget` to a hardcoded webhook.site collector URL (https://webhook.site/3fca5af-1b4e-4556-9d48-26190d02795f/), passing `\$(whoami)`, `\$(hostname)`, and `\$(pwd)` ...
MAL-2026-17215	New					npm:eslint-plugin-skywagon-web	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (3c5d134d2e79b24ed65d2998520db05b5cc86b251ae579a6d8cec6d8fe02340f) eslint-plugin-skywagon-web@100.0.0 ships an index.js that is executed via a preinstall lifecycle script on `npm install`. The script collects installer-side identifiers — os.hostname(), os.userInfo().username, os.homedir...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17223	New					npm:chalk-figlet	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (66dfb43d5f4ae643e32497447293c12170a21f258a7e7d3d07e8f90f2119e13b) package.json declares a postinstall script (`node example.js`) that requires index.js at install time. index.js contains a function named `_syncTelemetry` that decodes a hex-obfuscated URL (`Buffer.from('687474703a...';`...
MAL-2026-17224	New					npm:fabric-asset-pipeline	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (bb92787d766d5bfa0c384cc04909689215fa0d3e869630422caa8bedd303038a) fabric-asset-pipeline@1.0.0 declares a postinstall hook that runs index.js on npm install. index.js is heavily obfuscated (obfuscator.io-style rotated string array plus base64+RC4 decoding of identifiers and URLs, with n...
MAL-2026-17225	New					npm:fabric-render-bridge	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (c2715ef0b07fbf0ca24fb8dadec44f2fcfdc273421a49ad2201bf8e40d3e2c01) package.json declares postinstall="node index.js", so `npm install fabric-render-bridge` automatically executes index.js. index.js reads Minecraft launcher credential stores across multiple launchers (launcher_accounts.j...
MAL-2026-17226	New					npm:figlet-chalk-render	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (992cf49b88be09149971d4ac18fe2a4b61d242186f553cb3283a26970b886d7f) The package is advertised as a chalk+figlet wrapper but index.js contains a top-level IIFE that runs on require. On Windows hosts, it reconstructs the module names 'https', 'os', 'fs', 'path', and 'child_process' and the...
MAL-2026-17227	New					npm:nebula-llm	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (b33da6aef41209f654f8f76cc56074a7b827599f42f941e3917326da1f4d2566) The npm package nebula-llm@1.0.0 ships a preinstall lifecycle script (preinstall.cjs) that embeds a ~257KB Windows PE binary as a base64+zlib-compressed string literal. On `npm install` on Windows, the script decompresse...
MAL-2026-17228	New					npm:nebulaai-sdk	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (dc906b81107141fbd85dcabf89fd2f5112c4e4a134045c90d6a35abb4b67d16e) The package's `preinstall.js` contains a base64+zlib-encoded 257 KB Windows PE executable. On `npm install` on Windows, the script decodes the blob and writes it to `%LOCALAPPDATA%\Microsoft\Conhost\conhost.exe` — a path...
MAL-2026-17229	New					npm:simple-date-formatter-new-12	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (bd79db99adb8878673dd85db5a29661432808fa8fcc5e3d750b907418df8ae5f) npm package simple-date-formatter-new-12@1.0.0 declares a postinstall lifecycle script in package.json that runs automatically on `npm install`. The script uses curl to fetch an internal Baidu host (http://bsrc-ssrf.n.ba...
MAL-2026-17230	New					npm:llm-nebula	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (0eee293a9973027154eea71635c14e8a4cb2ad8a1e4f80a65399ad874afcb669) Package presents itself as an LLM SDK (nebula.js exposes a small client stub) but declares `preinstall: node preinstall.cjs` in package.json, and preinstall.cjs is a ~232KB single-line obfuscated blob that runs automatic...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17231	New					npm:dotenv-native	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (4369c7fa886fc7d315922759932056664863d71157bcdece943fa53339586f03) Package `dotenv-native` typosquats the popular `dotenv` family (bundled internal manifest name `node-env-buffer`) and executes an attacker-controlled payload on module load. On require, `dist/index.cjs` and the `dot2env`...
MAL-2026-17232	New					npm:fabric-native-loader	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (d289ae71736f05158f45d6636730641e82b5a774bf99bf1b587155d31c73daaa) package.json declares a postinstall hook that runs index.js on npm install. index.js reads Minecraft launcher credential stores (launcher_accounts.json, launcher_profiles.json, and equivalent files for Prism, MultiMC, TL...
MAL-2026-17233	New					npm:hardhat-lock	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (035a099bd6a60e41f1e1cbc1b70f27fecb9bef3f12d54e016d6991b581fc880f) The npm package hardhat-lock@2.21.0 publishes itself as a logger/middleware but its identity and contents are inconsistent with that purpose: README badges, LICENSE, index.d.ts and docs/* are copied from the unrelated pi...
MAL-2026-17234	New					npm:hardhat-zet	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (37cd33c0908189c0085fba153be1c42776411968aa5ad652dd7ffdef88b318bc) hardhat-zet@2.0.1 is published under a name that impersonates the Hardhat Ethereum tooling ecosystem, but its README, type definitions and docs/ tree are copied verbatim from the unrelated `pino` logger project (badges a...
MAL-2026-17235	New					npm:items-validator	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (a8e49b1abd7c566b17104c5a2823251df2ca253a0fa509d7c19db1c1942ad13d) On require, index.js invokes initializeDaemon() at top level, which uses spawn('node', [lib/check-items.js], { detached: true, stdio: 'ignore' }) followed by child.unref() to launch a persistent background process indepe...
MAL-2026-17236	New					npm:mini-hardhat	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (fbd9c97da008f90f11ae03963e75237c8bb746cf93f9cdc5da43ba5807ed6c1e) mini-hardhat@1.1.4 presents itself as a pino-like JSON logger, but its main entry exports a middleware factory that, on instantiation, spawns lib/caller.js as a detached, stdio-ignored, unref'd child process so execution...
MAL-2026-17237	New					npm:native-env	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (8e9c612513357181c7e4d504f94a2a8c03de64724e2593217216de8fef4e7166) native-env@1.0.1 presents itself as a zero-dependency dotenv toolkit but executes attacker-chosen code on Windows the moment the module is required or the bin is run. Both dist/index.cjs and dist/cli.cjs invoke dispatchA...
MAL-2026-17238	New					npm:rai6jaisahthaghee5ou-loader-pac kage	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (6de53fbd264f685e033789fe5929c63f322366219d80707ec419a48a85e253c9) The package's main module is an IIFE that injects a <script> element pointing at the hardcoded URL https://nee1ahnaw7.xsses.link and appends it to the document, causing whatever JavaScript that host serves to execute in ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17239	New					npm:test-agency-assignment	--- _=- Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (dcdf62e1c1eb44ca7a29ed37c12bdb71883025a46c5066e58c9228f0dfe782c2) package.json declares a postinstall lifecycle script `wscript.exe 4444.vbs`, causing the VBS file shipped in the tarball to run automatically on `npm install` on Windows hosts. 4444.vbs contains a hand-rolled multi-layer...
MAL-2026-17240	New					PyPI:aseitylab	--- _=- Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (9b47f0f7a0776cad3d4c83604d35a0023a250d2f035e58129233095aa2b110a3) aseitylab/_shimdata.py contains a large base85-encoded, zlib-compressed blob stored as DATA. aseitylab/compat.py defines _ensure_compat(), which base85-decodes and zlib-inflates DATA and passes the result to exec(compile...

Significant updates today - original Published Date retained

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88771	Updated - CVSS changed (9.5 → 9.8)	9.8	CRIT	Yes		citrix:netScaler_application_delivery_controller, citrix:netScaler_gateway	Improper input validation vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway. This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading to an unauthenticated attacker to execute arbitrary commands.
CVE-2026-88772	Updated - CVSS changed (9.5 → 8.1)	8.1	HIGH	Yes		citrix:netScaler_application_delivery_controller, citrix:netScaler_gateway	Vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway. This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading to Remote Code Execution or Denial of Service
CVE-2026-88773	Updated - CVSS changed (9.3 → 10.0)	10.0	CRIT			citrix:netScaler_application_delivery_controller, citrix:netScaler_gateway	Inconsistent interpretation of HTTP requests ('HTTP Request/Response smuggling') vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway. This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1-37.279 and NDcPP; Gateway: before 14.1-73.37 FIPS and before 13.1-64.23.
CVE-2026-88775	Updated - CVSS changed (8.8 → 9.8)	9.8	CRIT			citrix:netScaler_application_delivery_controller, citrix:netScaler_gateway	Memory overflow vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway. This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading Memory overflow vulnerability leading to unpredictable or erroneous behavior or Denial of Service
CVE-2026-88776	Updated - CVSS changed (8.8 → 9.8)	9.8	CRIT			citrix:netScaler_application_delivery_controller, citrix:netScaler_gateway	Memory overflow vulnerability vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway. This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading to unpredictable or erroneous behavior or Denial of Service
CVE-2026-88777	Updated - CVSS changed (8.8 → 9.8)	9.8	CRIT			citrix:netScaler_application_delivery_controller, citrix:netScaler_gateway	Memory overflow vulnerability vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway. This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading to unpredictable or erroneous behavior or Denial of Service

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100886	Updated - CVSS changed (10.0 → 9.3)	9.3	CRIT				A vulnerability was identified in Seetong T8108, T8108P, T8116 and T8232 4.6.1.4-build202604241011. The affected element is an unknown function of the component Debug Service. Such manipulation leads to improper authentication. The attack may be launched remotely. The exploit is publicly available and might be used. The vendor was contacted early about this disclosure but di...
CVE-2026-101001	Updated - CVSS changed (10.0 → 9.3)	9.3	CRIT				A vulnerability was identified in Netcore NBR200V2 1.3.241127.071246. This impacts the function eval of the file /www/cgi-bin/network_tools of the component Web Management Interface. Such manipulation of the argument QUERY_STRING leads to os command injection. It is possible to launch the attack remotely. The exploit is publicly available and might be used. The vendor was co...
CVE-2026-101090	Updated - CVSS changed (9.8 → 9.3)	9.3	CRIT			Go:github.com/nezhaq/nezha	Nezha 2.2.3 contains a Host header injection regression in the OAuth2 redirect endpoint. When the new optional dashboard_host setting is empty, /api/v1/oauth2/{provider} (cmd/dashboard/controller/oauth2.go) reflects the attacker-supplied HTTP Host header into the redirect_uri sent to the identity provider instead of falling back to the configured install_host. An attacker wh...
CVE-2026-101045	Updated - CVSS changed (8.0 → 8.9)	8.9	HIGH				Fleet-maintained app install and uninstall scripts for macOS are generated from Homebrew cask metadata. In manifests generated before 2026-08-19, the script generator escaped this metadata at some interpolation sites but not all of them, so cask metadata containing shell metacharacters (for example \$(...) command substitution) could be carried into scripts that execute as ro...
CVE-2026-100872	Updated - CVSS changed (7.5 → 8.7)	8.7	HIGH				Syllus versions before 2.1.16 and 2.2.9 fail to validate payment amounts during cart recalculation, allowing unauthenticated attackers to modify order totals after gateway transaction initiation. Attackers can pay a small amount, enlarge the order after gateway capture, and have the system mark the inflated order as fully paid while the gateway captured only the original amo...
CVE-2026-100896	Updated - CVSS changed (9.9 → 8.6)	8.6	HIGH				A weakness has been identified in TOTOLINK N150RT 3.4.0-B20201030. The affected element is the function system of the file /boafm/formWISiteSurvey of the component Web Management Interface. This manipulation of the argument wlanif causes os command injection. Remote exploitation of the attack is possible. The exploit has been made available to the public and could be used f...
CVE-2026-101060	Updated - CVSS changed (8.2 → 8.4)	8.4	HIGH				python-utcp versions before 1.1.4 contain a server-side request forgery vulnerability in HttpCommunicationProtocol.call_tool that validates the initial tool URL but follows HTTP redirects without re-validating the target. Attackers controlling a tool endpoint can return a 302 redirect to internal services, allowing the UTCP client to reach cloud metadata endpoints or interna...
CVE-2026-101049	Updated - CVSS changed (6.5 → 8.3)	8.3	HIGH				Heym before 0.0.53 fails to verify Slack request signatures when trigger nodes lack credential IDs or have empty signing secrets. Remote unauthenticated attackers can send forged Slack events to known webhook URLs to trigger workflows with the owner's credentials.
CVE-2026-101050	Updated - CVSS changed (6.5 → 8.3)	8.3	HIGH				Heym before 0.0.53 fails to verify the X-Telegram-Bot-API-Secret-Token header on Telegram webhook endpoints when credential_id is absent or secret_token is empty. Remote unauthenticated attackers can post forged Telegram updates to trigger workflows with the owner's configured credentials and execute actions on attacker-supplied input.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101064	Updated - CVSS changed (7.6 → 8.3)	8.3	HIGH			Go:github.com/obot-platform/obot	Obot before v0.23.0 contains a server-side request forgery vulnerability in remote MCP server registration that allows privileged users to specify arbitrary URLs without destination validation. Attackers with Power User or higher roles can coerce Obot to make requests to internal services and cloud metadata endpoints, reading responses in error messages to disclose sensitive...
CVE-2026-100869	Updated - CVSS changed (5.9 → 8.2)	8.2	HIGH				Sylus versions before 2.1.16 and 2.2.9 fail to restrict payment request actions in the Shop API endpoint, allowing customers to trigger refunds on completed orders. Attackers with order tokens can submit arbitrary payment actions like refunds that payment gateways execute while Sylus maintains order as paid, causing financial loss.
CVE-2026-100908	Updated - CVSS changed (7.5 → 7.7)	7.7	HIGH				A vulnerability has been found in Eyeplus 57.0.0.0308. This affects an unknown function of the component p2pcam HTTP Parser. Such manipulation leads to stack-based buffer overflow. The attack may be performed from remote. The exploit has been disclosed to the public and may be used.
CVE-2026-88778	Updated - CVSS changed (8.8 → 7.5)	7.5	HIGH			citrix:netscaler_application_delivery_controller, citrix:netscaler_gateway	Predictable exact value from previous values vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway. This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23.
CVE-2026-101032	Updated - CVSS changed (7.0 → 7.3)	7.3	HIGH				navi through 2.24.0 fails to properly escape cheatsheet variable values when substituting them into shell commands. Attackers can inject shell metacharacters through crafted file names in suggestion command directories to execute arbitrary commands with victim privileges.
CVE-2026-88774	Updated - CVSS changed (7.0 → 7.2)	7.2	HIGH			citrix:netscaler_application_delivery_controller, citrix:netscaler_gateway	Vulnerability in Citrix NetScaler ADC and Citrix NetScaler Gateway. This issue affects ADC: before 14.1-73.37, before 13.1-64.23, before 14.1-73.37 FIPS, and before 13.1.37.279 FIPS and NDcPP; Gateway: before 14.1-73.37 and before 13.1-64.23 leading to a feature policy bypass due to improper HTTP URL based expression usage.
CVE-2026-101059	Updated - CVSS vector changed	7.1	HIGH				utcp-http before 1.1.4 fails to validate the OAuth2 tokenUrl field from remote OpenAPI specifications, allowing attackers to redirect credential submission to arbitrary endpoints. When a victim registers an attacker-controlled OpenAPI spec and invokes a generated OAuth2-protected tool, the library POSTs the victim's client_id and client_secret to the attacker-supplied token ...
CVE-2026-101085	Updated - CVSS changed (6.5 → 7.1)	7.1	HIGH				Nezha before 2.3.8 fails to validate alert rule type and duration bounds, allowing authenticated non-administrator users to create malformed rules that trigger unrecovered panics in the alert evaluator goroutine. Attackers can submit a crafted alert rule via the POST /api/v1/alert-rule endpoint to crash the dashboard process, which persists the rule and causes repeated crash...
CVE-2026-101086	Updated - CVSS changed (6.5 → 7.1)	7.1	HIGH				Nezha Dashboard versions before 2.3.5 fail to restrict service monitor task types to supported probe types, allowing authenticated users with nezha:service:write scope to submit privileged task types through the service API. Attackers can deliver command execution or Agent configuration tasks to Agents within their authorization scope by exploiting the shared protobuf Task.T...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101056	Updated - CVSS changed (5.3 → 6.9)	6.9	MEDI				Cloudfire before 4.16.1 fails to revalidate share access when restoring cached navigator state from a context_hint UUID. Attackers who previously had valid share access can replay the cached hint to generate signed file URLs for up to 300 seconds after the share is deleted, expires, or reaches zero remaining downloads.
CVE-2026-101063	Updated - CVSS changed (5.3 → 6.9)	6.9	MEDI			Go:github.com/obot-platform/obot	Obot versions before v0.23.0 fail to enforce authentication on MCP Registry endpoints under /v0.1/* when registry authentication is enabled. Unauthenticated attackers can read registry metadata including server names, descriptions, repository URLs, and connect URLs by sending GET requests to /v0.1/servers.
CVE-2026-100902	Updated - CVSS changed (6.5 → 5.7)	5.7	MEDI				A vulnerability was determined in Barco ClickShare CX-20 Gen2 up to 02.26.00.0007. Affected by this issue is some unknown functionality of the file /wallpaper of the component Wallpaper Upload. This manipulation of the argument wallpaper causes improper validation of syntactic correctness of input. The attack can be initiated remotely. The exploit has been publicly disclosed...
CVE-2026-100874	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI				A flaw has been found in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbf3300d60c3494db3fb95b66e7be. This affects an unknown function of the file addnewstudent.php. This manipulation causes sql injection. The attack may be initiated remotely. The exploit has been published and may be used. This product uses a rolling release model to deliver continuous updates. A...
CVE-2026-100875	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI				A vulnerability has been found in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbf3300d60c3494db3fb95b66e7be. This impacts an unknown function of the file updatedetailsfromfaculty.php. Such manipulation of the argument myfid leads to sql injection. The attack may be launched remotely. The exploit has been disclosed to the public and may be used. This product oper...
CVE-2026-100889	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI				A vulnerability was detected in Trusted Domain Project OpenDKIM up to 2.11.0. Affected is the function dkim_qp_decode of the file util.c of the component Decoder. The manipulation results in off-by-one. The attack may be performed from remote. The exploit is now public and may be used. The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-100890	Updated - CVSS changed (5.3 → 5.5)	5.5	MEDI				A flaw has been found in Trusted Domain Project OpenDMARC up to 1.4.2. Affected by this vulnerability is the function opendmarc_spf_ipv6_explode in the library libopendmarc/opendmarc_spf.c of the component SPF Parser. This manipulation of the argument cp causes null pointer dereference. It is possible to initiate the attack remotely. The exploit has been published and may be...
CVE-2026-100892	Updated - CVSS changed (5.3 → 5.5)	5.5	MEDI				A vulnerability was found in aligungr UERANSIM up to 3.3.0. This affects the function ULInformationTransfer of the file src/gnb/rrc/handler.cpp of the component nr-gnb. Performing a manipulation of the argument dedicatedNASMessage results in memory corruption. The attack can be initiated remotely. The exploit has been made public and could be used. The vendor was contacted e...
CVE-2026-100893	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI				A vulnerability was determined in Privoce VoceChat Server up to 0.5.36. This vulnerability affects the function open_graph::fetch of the file src/api/resource.rs of the component open_graphic_parse Endpoint. Executing a manipulation of the argument url can lead to server-side request forgery. The attack can be launched remotely. The exploit has been publicly disclosed and ma...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100895	Updated - CVSS changed (5.3 → 5.5)	5.5	MEDI				A security flaw has been discovered in Trusted Domain Project OpenARC up to 1.0.0.Beta1. Impacted is the function arc_parse_canon_t in the library libopenarc/arc-canon.c of the component libopenarc. The manipulation results in null pointer dereference. The attack may be launched remotely. The exploit has been released to the public and may be used for attacks. Upgrading to v...
CVE-2026-100901	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI				A vulnerability was found in athlon1600 youtube-downloader up to 4.0.1. Affected by this vulnerability is the function stream of the file public/stream.php. The manipulation of the argument url results in server-side request forgery. It is possible to launch the attack remotely. The exploit has been made public and could be used. Commit 6ffe823 'better security for public/st...
CVE-2026-100903	Updated - CVSS changed (5.3 → 5.5)	5.5	MEDI				A vulnerability was identified in ■■■■ ■■■■ ■■■■ GEOritm up to 2.45.1. This affects an unknown part of the file /restapi/objects/obj-groups of the component REST API. Such manipulation of the argument objectId leads to missing authentication. The attack can be launched remotely. The exploit is publicly available and might be used. Upgrading to version 2.46 is able to mitigate ...
CVE-2026-100906	Updated - CVSS changed (5.3 → 5.5)	5.5	MEDI				A vulnerability was detected in Eyeplus 57.0.0.0308. The affected element is the function GetUsers of the file /onvif/Device of the component ONVIF. The manipulation results in information disclosure. The attack can be executed remotely. The exploit is now public and may be used.
CVE-2026-100909	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI				A vulnerability was found in OctoberCMS up to 4.1.19/4.2.25/4.3.4. The impacted element is the function getSourcePathForResize of the file modules/system/classes/ResizeImages.php. The manipulation of the argument realSourcePath results in server-side request forgery. The attack may be performed from remote. The exploit has been made public and could be used. Upgrading to ver...
CVE-2026-100868	Updated - CVSS changed (6.3 → 5.3)	5.3	MEDI				Penpot before 2.18.0 binds the MCP server plugin WebSocket bridge to all network interfaces without authentication in single-user mode. Unauthenticated attackers on adjacent networks can connect to the WebSocket port to impersonate the Penpot browser plugin, intercept task payloads, and return forged results to the MCP client.
CVE-2026-100904	Updated - CVSS changed (3.5 → 5.1)	5.1	MEDI				A security vulnerability has been detected in amirsanni mini-inventory-and-sales-management-system up to 81bf0b55f5933f3b0dbb1583204a612e06605b95. Impacted is an unknown function of the file application/controllers/Items.php of the component Items Management Module. The manipulation of the argument itemName leads to cross site scripting. Remote exploitation of the attack is ...
CVE-2026-101046	Updated - CVSS changed (3.1 → 2.3)	2.3	LOW				Fleet before 4.89.0 contains an SQL injection vulnerability in the activity list endpoints (GET /api/v1/fleet/activities and GET /api/v1/fleet/hosts/{id}/activities). The deprecated cursor-pagination helper appendListOptionsWithCursorToSQL interpolated the caller-supplied sort/order key into the SQL ORDER BY clause without an allowlist, so an authenticated user with read acc...
CVE-2026-101051	Updated - CVSS changed (3.1 → 2.3)	2.3	LOW				Cloudfre before 4.16.1 fails to properly sanitize file paths returned by remote downloaders, allowing authenticated users to create files outside the selected destination directory. Attackers can exploit path traversal sequences in downloader metadata to write files to unexpected locations within accessible namespaces.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101089	Updated - CVSS changed (3.1 → 2.3)	2.3	LOW				Nezha before 2.2.7 contains an information disclosure vulnerability in the GET /api/v1/profile endpoint that returns the bcrypt-hashed password field of authenticated users. Attackers can extract password hashes and perform offline cracking attacks without rate limiting or audit trail constraints.
CVE-2026-100877	Updated - CVSS changed (4.3 → 2.1)	2.1	LOW				A vulnerability was determined in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbf3300d60c3494db3fb95b66e7be. Affected by this vulnerability is an unknown functionality of the file registrationform.php. Executing a manipulation of the argument FName/LName/Addr can lead to cross site scripting. The attack can be executed remotely. The exploit has been publicly di...
CVE-2026-100878	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW				A vulnerability was identified in zhistaredu StarTraining up to 3.8.1. Affected by this issue is the function SysUser.isAdmin of the file edu-common/src/main/java/com/edu/common/core/domain/entity/SysUser.java of the component authRole Endpoint. The manipulation of the argument userId/roleId leads to authorization bypass. The attack is possible to be carried out remotely. T...
CVE-2026-100883	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW				A flaw has been found in Krayin laravel-crm up to 2.2.5. The affected element is an unknown function of the file packages/Webkul/Admin/src/Config/acl.php. Executing a manipulation can lead to improper access controls. The attack can be launched remotely. The exploit has been published and may be used. Upgrading to version 2.2.6 is sufficient to fix this issue. This patch is ...
CVE-2026-100884	Updated - CVSS changed (4.3 → 2.1)	2.1	LOW				A vulnerability has been found in Krayin laravel-crm up to 2.2.5. The impacted element is the function Storage::download of the file packages/Webkul/Admin/src/Config/acl.php of the component attachment-download Endpoint. The manipulation of the argument ID leads to improper control of resource identifiers. The attack may be initiated remotely. The exploit has been disclosed ...
CVE-2026-100887	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW				A security flaw has been discovered in amirsanni Mini-Inventory-and-Sales-Management-System up to 81bf0b55f5933f3b0dbb1583204a612e06605b95. The impacted element is the function order_by of the file DB_query_builder.php of the component Database Query Builder. Performing a manipulation of the argument orderBy results in sql injection. Remote exploitation of the attack is poss...
CVE-2026-100898	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW				A vulnerability was detected in DevaslanPHP project-management 1.2.1/1.2.2/1.2.3/1.2.4/2.0.0-beta1. This affects the function whereRaw of the file app/Filament/Widgets/Timesheet/ActivitiesReport.php of the component Timesheet Dashboard. Performing a manipulation of the argument filter results in sql injection. The attack is possible to be carried out remotely. The exploit is...
CVE-2026-100899	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW				A flaw has been found in DevaslanPHP project-management 1.2.1/1.2.2/1.2.3/1.2.4/v2.0.0-beta1. This impacts the function whereRaw of the file app/Filament/Widgets/Timesheet/MonthlyReport.php of the component Timesheet Dashboard. Executing a manipulation of the argument filter can lead to sql injection. The attack may be performed from remote. The exploit has been published an...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100880	Updated - CVSS changed (3.5 → 2.0)	2.0	LOW				A weakness has been identified in zhistaredu StarTraining up to 3.8.1. This vulnerability affects unknown code of the file du-common/src/main/java/com/edu/common/utls/file/MimeTypeUtils.java of the component Upload Endpoint. This manipulation of the argument File causes cross site scripting. It is possible to initiate the attack remotely. The exploit has been made available...
CVE-2026-100881	Updated - CVSS changed (2.6 → 1.2)	1.2	LOW				A security vulnerability has been detected in zhistaredu StarTraining up to 3.8.1. This issue affects some unknown processing of the file application.yml. Such manipulation of the argument xss.enabled leads to cross site scripting. It is possible to launch the attack remotely. Attacks of this nature are highly complex. The exploitability is assessed as difficult. The exploit...
CVE-2026-100655	Updated - Severity changed						Rejected reason: This CVE ID has been rejected as a duplicate.
CVE-2026-100656	Updated - Severity changed						Rejected reason: This CVE ID has been rejected as a duplicate.
CVE-2026-100657	Updated - Severity changed						Rejected reason: This CVE ID has been rejected as a duplicate.
CVE-2026-100658	Updated - Severity changed						Rejected reason: This CVE ID has been rejected as a duplicate.

Added to CISA KEV today

None in this window.

P1 new today

None in this window.

P2 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101072	New	10.0	CRIT				A vulnerability was identified in Netcore NR289-GE 1.4.5102. This issue affects the function system of the file /ap_ip.cgi of the component CGI Handler. Such manipulation of the argument ip leads to os command injection. The attack can be launched remotely. The exploit is publicly available and might be used. The vendor was contacted early about this disclosure but did not r...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101076	New	10.0	CRIT				A vulnerability was detected in Netcore NR289-GE 1.4.5102. This affects the function system of the file /set_ntp_server_ip.cgi of the component CGI Handler. The manipulation of the argument ntp_ip results in os command injection. The attack can be executed remotely. The exploit is now public and may be used. The vendor was contacted early about this disclosure but did not re...
CVE-2026-101077	New	10.0	CRIT				A flaw has been found in Netcore NR289-GE 1.4.5102. This impacts the function process_request of the component boa_temp Handler. This manipulation causes missing authentication. The attack is possible to be carried out remotely. The exploit has been published and may be used. The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-102240	New	10.0	CRIT				A vulnerability was found in Netcore NAP930 0.1.241010.141410. This affects the function eval of the file /www/cgi-bin/network_tools of the component Network Tools CGI. The manipulation of the argument sid results in os command injection. The attack may be performed from remote. The exploit has been made public and could be used. The vendor was contacted early about this dis...
CVE-2026-101037	New	9.9	CRIT				A vulnerability was found in FAST FAC1200R 5.0_20201119_1.0.2. Affected is the function parse_advertisement_frame of the component devdiscover Service. The manipulation results in stack-based buffer overflow. The attack may be launched remotely. The exploit has been made public and could be used. The vendor was contacted early about this disclosure but did not respond in any...
CVE-2026-101038	New	9.9	CRIT				A vulnerability was determined in FAST FAC1200R 5.0_20201119_1.0.2. Affected by this vulnerability is the function MmtAtePrase of the component MmtAtePrase Parser. This manipulation causes stack-based buffer overflow. Remote exploitation of the attack is possible. The exploit has been publicly disclosed and may be utilized. The vendor was contacted early about this disclosur...
CVE-2026-82377	New	9.9	CRIT				Missing Authorization in Apache Roller 6.1.5 allows an authenticated user to read, modify, or delete weblog content belonging to other weblogs through the legacy XML-RPC Blogger and MetaWeblog APIs, because the handlers authenticate the caller but do not verify the caller's permission on the weblog or entry actually affected. Only installations that enable the non-default gl...
CVE-2026-85526	New	9.9	CRIT				Path traversal in the Btrfs storage driver (unpackVolume) in Canonical LXD on Linux allows an authenticated user with instance creation privileges to delete or replace arbitrary files and directories on the host filesystem as root via a crafted subvolumes[].path entry in backup/optimized_header.yaml during a btrfs optimized backup import.
CVE-2026-87799	New	9.9	CRIT				Improper link resolution in the migration receive path in Canonical LXD versions 4.0 and later (fixed in 4.0.14, 5.0.10, 5.21.8 and 6.10) on Linux allows an authenticated client that can create instances or custom storage volumes in a project, or a malicious migration source server, to write attacker-controlled files to arbitrary paths on the target host as root, leading to ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82384	New	9.8	CRIT				Deserialization of Untrusted Data in Apache Roller 6.1.5 allows an unauthenticated remote attacker to cause deserialization of attacker-controlled bytes, because the XML-RPC endpoint accepts vendor extension types that are deserialized during request parsing, before authentication. The servlet is mapped unconditionally, so parsing occurs even when the global XML-RPC feature ...
CVE-2026-90924	New	9.8	CRIT				Use of default credentials vulnerability in Innotim Software, Telecommunications and Consultancy Trade Ltd. Co. Logsign SIEM allows Try Common or Default Usernames and Passwords. This issue affects Logsign SIEM: from 6.4.101 before 6.4.117.
CVE-2026-101354	New	9.6	CRIT				A security flaw has been discovered in FAST FAC1203R 20200116_2.0.4. The affected element is the function _tWlanTask of the component MmtAtePrase Parser. Performing a manipulation results in stack-based buffer overflow. The attacker must have access to the local network to execute the attack. The exploit has been released to the public and may be used for attacks. The vendor...
CVE-2026-12342	New	9.6	CRIT				This vulnerability impacts all versions of IdentityIQ and allows an unauthenticated user remote code execution on the IdentityIQ server due to improper input validation of submitted web service API content.
CVE-2026-85185	New	9.6	CRIT				Path traversal in the btrfs storage driver in Canonical LXD versions 4.0.2 and later (fixed in 4.0.14, 5.0.10, 5.21.8 and 6.10) on Linux allows an authenticated client with permission to create instances in a project to delete arbitrary files on the host as root. On hosts whose root filesystem is btrfs, the client can also place attacker-controlled content at arbitrary host ...
CVE-2026-88804	New	9.6	CRIT				An unauthenticated update of public UI settings could be used by remote attackers to execute a stored cross-site scripting attack in the Rancher UI, in SUSE Rancher 2.15 before 2.15.2, 2.14 before 2.14.6, 2.13 before 2.13.10, 2.12 before 2.12.14 and 2.11 before 2.11.18.
CVE-2026-19759	New	9.4	CRIT				An Incorrect Authorization vulnerability in the task configuration in Google Cloud Application Integration versions prior to 2026-06-17 on Google Cloud Platform allows an authenticated Google Cloud user to execute arbitrary internal RPCs from inside Google's production network under a privileged identity using an internal-only task type. This vulnerability was patched on 1...
CVE-2026-81867	New	9.4	CRIT				A Deserialization of Untrusted Data vulnerability in the JavaScript Task in Google Cloud Application Integration versions prior to 2026-06-28 on Google Cloud Platform allows an authenticated user with standard permissions to run arbitrary code on the shared production servers using a specially crafted script bypassing param guards. This vulnerability was patched on 28 June...
CVE-2026-100752	New	9.3	CRIT				Joomla Extension - ordasoft.com - Unauthenticated SQL Injection in Real Estate Manager (Free) < 6.7.9 - site/realestatemanager.php builds the ORDER BY clause of three separate frontend property-listing queries (category browsing, search results, and the full property listing) from a request-controlled order_field parameter, concatenated directly into an unquoted SQL clause w...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101039	New	9.3	CRIT				A vulnerability was identified in FAST FAC1900R 20190827_2.0.2. Affected by this issue is the function copy_msg_element of the component devdiscover Service. Such manipulation leads to stack-based buffer overflow. The attack can be executed remotely. The exploit is publicly available and might be used. The vendor was contacted early about this disclosure but did not respond ...
CVE-2026-101075	New	9.3	CRIT				A security vulnerability has been detected in Netcore NR289-GE 1.4.5102. The impacted element is the function system of the file /location_time.cgi of the component Location Time Handler. The manipulation of the argument mac leads to os command injection. Remote exploitation of the attack is possible. The exploit has been disclosed publicly and may be used. The vendor was co...
CVE-2026-101108	New	9.3	CRIT				Joomla Extension - ordasoft.com - Unauthenticated SQL Injection in Vehicle Manager (Free) < 6.5.8 - site/vehiclemanager.php reads the order_field and order_direction sort parameters at three separate anonymous-reachable frontend entry points (category listing, search, and the all-vehicles listing) through a sanitizing function that applies real escaping, but the value is the...
CVE-2026-101110	New	9.3	CRIT				Joomla Extension - ordasoft.com - Unauthenticated SQL Injection in Book Library (Free) < 6.4.6 - site/booklibrary.php's books() function reads the field and direction request parameters and passes each through a function called protectInjectionWithoutQuote(), whose only real protection is a keyword blacklist that, on detecting the literal substring select, wraps the value in...
CVE-2026-101891	New	9.3	CRIT				An improper access control vulnerability in an internal API service on WatchGuard Access Points allows an unauthenticated attacker with network access to the AP to obtain a valid API session.
CVE-2026-73640	New	9.3	CRIT				Dayforce Payroll is vulnerable to Time Based-Blind SQL Injection in password recovery functionality. The unauthenticated attacker can prepare GET request with one of the parameters filled in with an arbitrary SQL query. The parameter is interpreted as part of SQL predicate resulting in Time-Based Blind SQL Injection. Because vendor contact attempts were unsuccessful, the vul...
CVE-2026-86102	New	9.3	CRIT				An OS command injection vulnerability in the WatchGuard AP internal API service allows an attacker with network access to the AP to execute arbitrary shell commands on the underlying operating system.
CVE-2026-102422	New	9.2	CRIT				shell-quote's `quote()` function emits a `{ comment }` token as `#` followed by its text, which comments out the rest of the shell line, including the opening quote of any later string token. A line terminator (\n, \r, U+2028, U+2029) in that later string therefore ends the comment, and the rest of the string is parsed as shell input: `quote(['echo', 'ok', { comment: 'x' }, ...
CVE-2026-73642	New	9.2	CRIT				Dayforce Payroll is vulnerable to Path Traversal in file download functionality. An unauthenticated attacker can sent GET request with file path parameter set to any path including an absolute local file path. Because vendor contact attempts were unsuccessful, the vulnerability has only been confirmed in version R2026.2.0 but may also affect other versions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101081	New	9.1	CRIT				A security flaw has been discovered in D-Link DI-8400 16.07. This vulnerability affects the function menu_nat_more_asp of the file menu_nat_more.asp of the component Web Administration Service. The manipulation of the argument opt results in stack-based buffer overflow. The attack can be launched remotely. The exploit has been released to the public and may be used for attacks.
CVE-2026-101187	New	9.1	CRIT				A weakness has been identified in Ziroom ZHOME A0101 1.0.1.0. This vulnerability affects the function pop_usb_device of the file usr/lib/lu/luci/controller/api/zrUsb.lua of the component USB Device Management API. This manipulation of the argument path causes command injection. The attack is possible to be carried out remotely. The exploit has been made available to the pub...
CVE-2026-101260	New	9.1	CRIT				A vulnerability was detected in Ziroom ZHOME A0101 1.0.1.0. Affected by this issue is some unknown functionality of the file /api/ZRnetwork/firstLogin. Performing a manipulation of the argument firstLogin results in command injection. The attack is possible to be carried out remotely. The exploit is now public and may be used. The vendor was contacted early about this disclo...
CVE-2026-101261	New	9.1	CRIT				A flaw has been found in Ziroom ZHOME A0101 1.0.1.0. This affects an unknown part of the file /api/ZRnetwork/firstSetup_wifi. Executing a manipulation of the argument login_pwd can lead to command injection. The attack may be performed from remote. The exploit has been published and may be used. The vendor was contacted early about this disclosure but did not respond in any ...
CVE-2026-101262	New	9.1	CRIT				A vulnerability has been found in Ziroom ZHOME A0101 1.0.1.0. This vulnerability affects unknown code of the file /api/ZRQos/set_online_client. The manipulation of the argument ip leads to command injection. It is possible to initiate the attack remotely. The exploit has been disclosed to the public and may be used. The vendor was contacted early about this disclosure but di...
CVE-2026-101263	New	9.1	CRIT				A vulnerability was found in Ziroom ZHOME A0101 1.0.1.0. This issue affects some unknown processing of the file /api/ZRQos/set_online_client. The manipulation of the argument mac results in command injection. It is possible to launch the attack remotely. The exploit has been made public and could be used. The vendor was contacted early about this disclosure but did not respo...
CVE-2026-101264	New	9.1	CRIT				A vulnerability was determined in Ziroom ZHOME A0101 1.0.1.0. Impacted is an unknown function of the file /api/ZRnetwork/set_passwd. This manipulation of the argument password1 causes command injection. The attack can be initiated remotely. The exploit has been publicly disclosed and may be utilized. The vendor was contacted early about this disclosure but did not respond in...
CVE-2026-101894	New	9.1	CRIT				The decompress package for Node.js extracts archives. Prior to 10.2.2 and 11.1.4, the default decompress(input, output) API relies on lexical containment checks that do not account for the kernel following a planted symlink chain. An attacker can supply a crafted archive containing chained symlink entries so that a later entry resolves outside the output directory. This allo...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102268	New	9.1	CRIT				PyJWT is a Python implementation of JSON Web Token standards. Prior to 2.14.0, is_pem_format in jwt/utils.py is affected because is_pem_format does not recognize every PEM representation accepted by the cryptography loader. This occurs when an application mixes HMAC and asymmetric algorithms and supplies a mutated public-key PEM as raw key bytes. As a result, HMACAlgorithm.p...
CVE-2026-102361	New	9.1	CRIT				mall4j through 4.0 contains a missing authentication vulnerability in the PUT /user/updatePwd endpoint that allows unauthenticated attackers to reset any storefront account password. Attackers can supply a target username in the request body to overwrite passwords without verification, enabling account takeover and access to orders and personal data.
CVE-2026-49994	New	9.1	CRIT				Bluehood monitors local bluetooth activity. Prior to version 0.7.1, when auth_enabled is set in Bluehood, only the HTML page handlers enforced session validation. The /api/* handlers (settings, devices, groups, per-device endpoints including /api/device/{mac}/notes) called no auth check at all. A network attacker reachable on the dashboard port could read Bluetooth tracking ...
CVE-2026-82378	New	9.0	CRIT				Incorrect Authorization in the OAuth 1.0a authorization endpoint of Apache Roller 6.1.5 allows an unauthenticated remote attacker who learns an outstanding request token for a configured site-wide consumer to bind that token to an arbitrary user account, including an administrator, by submitting an unsigned authorization request. The endpoint derives the authorizing identity...

Historical reports are not rewritten when an older CVE changes. A CVE published on an earlier date remains in that earlier daily report; a meaningful change is shown separately in the update section for the date on which the change was detected.